



UNIVERSITÀ DEGLI STUDI
DI SALERNO

Corso di

Algoritmi e Protocolli per la Sicurezza

A.A. 2025–2026

UniSafe

Sistema di Votazione Elettronico Sicuro

Docente

Francesco Cauteruccio

Studenti

Vittorio Postiglione - IE22700189

Mattia Sanzari - IE22700199

Indice

1	Introduzione	3
2	WP1 – Modello: Analisi di attori, funzionalità, minacce e contromisure di sicurezza	3
2.1	Analisi comparativa delle tipologie di elezione	3
2.1.1	Referendum Binario	3
2.1.2	Elezione a Lista Chiusa	4
2.1.3	Elezione con Preferenza Nominale	4
2.2	Scelta del Modello	5
2.3	Attori del Sistema	5
2.3.1	Sistema di Autenticazione (SA)	5
2.3.2	Autorità Elettorale (AE)	5
2.3.3	Client dell'Elettore	6
2.3.4	Osservatore Pubblico	6
2.4	Funzionalità del Sistema	6
2.5	Threat Model	6
2.5.1	Gestore Disonesto del Server (AE o SA corrotta)	6
2.5.2	Elettore Malevolo	7
2.5.3	Avversario Esterno Passivo (Eavesdropper)	7
2.5.4	Avversario Esterno Attivo	7
2.6	Proprietà di Sicurezza	8
2.6.1	Autenticità	8
2.6.2	Unicità del Voto (One Voter, One Vote)	8
2.6.3	Segretezza del Voto (Vote Privacy)	8
2.6.4	Integrità dei Voti	8
2.6.5	Verificabilità Individuale	9
2.6.6	Verificabilità Universale	9
2.6.7	Proprietà non pienamente garantite e compromessi	9
2.7	Analisi dell'Efficienza e Scalabilità (Qualitativa)	10
2.7.1	Efficienza Computazionale	10
2.7.2	Latenza e User Experience	10
2.7.3	Scalabilità del Sistema	11
2.7.4	Semplicità e Manutenibilità (Open Design)	11
3	WP2 – Soluzione: Protocollo di Voto Elettronico	12
3.1	Fase 1 – Inizializzazione	12
3.1.1	Generazione e distribuzione delle chiavi	13
3.2	Fase 2 – Autenticazione e Rilascio del Token	13
3.2.1	Politica di scadenza (Use-it-or-Lose-it)	13
3.3	Fase 3 – Votazione	14
3.3.1	Preparazione della scheda	14
3.3.2	Proof of Work Adattiva Globale	14
3.3.3	Verifiche dell'AE e registrazione	14
3.3.4	Ricevuta crittografica	15
3.4	Fase 4 – Scrutinio e Pubblicazione	15
3.5	Fase 5 – Verifica Individuale e Universale	16

3.5.1	Verifica individuale	16
3.5.2	Verifica universale	16
3.6	Limiti Dichiarati del Sistema	16
4	WP3 – Analisi della Sicurezza	17
4.1	Verifica delle Proprietà di Sicurezza	17
4.1.1	Autenticità	17
4.1.2	Unicità del Voto (One Voter, One Vote)	18
4.1.3	Segretezza del Voto (Vote Privacy)	18
4.1.4	Integrità dei Voti	19
4.1.5	Verificabilità Individuale	19
4.1.6	Verificabilità Universale	20
4.1.7	Riepilogo della Verifica	21
4.2	Analisi degli Avversari	21
4.2.1	Gestore Disonesto (AE o SA corrotta)	21
4.2.2	Elettore Malevolo	22
4.2.3	Avversario Esterno Passivo (Eavesdropper)	23
4.2.4	Avversario Esterno Attivo	23
4.3	Modifiche Migliorative	24
4.3.1	Commitment Pubblico del Numero di Token Emessi	24
4.3.2	Timestamp Firmato nella Ricevuta	25
4.3.3	Vincolo Crittografico sulla Chiave Privata di Decifratura	25
4.3.4	Certificate Pinning per la Chiave Pubblica dell'AE	26
4.3.5	Riepilogo delle Modifiche Migliorative	26
4.4	Compromessi Dichiarati e Motivazioni	27
4.4.1	Receipt-Freeness	27
4.4.2	Anonimato a Livello di Rete	27
4.4.3	Segretezza Condizionata alla Non-Collusione	27
4.4.4	Disponibilità del Servizio	28
4.5	Conclusioni	28
4.6	Riepilogo STRIDE	28
5	WP4 – Implementazione e Prestazioni	29
5.1	Architettura Software e Stack Tecnologico	29
5.1.1	Disaccoppiamento dei Moduli	30
5.2	Implementazione delle Primitive Crittografiche	30
5.3	Struttura del Registro Pubblico (Bulletin Board)	31
5.4	Flusso d'Esecuzione e Gestione dello Stato	31
5.5	Strategia di Testing e Analisi dei Casi d'Uso	35
5.5.1	Simulazione di Attacchi (Security Testing)	35
5.6	Analisi delle Prestazioni e Validazione Crittografica	36
5.6.1	Quadro Riassuntivo delle Verifiche di Sicurezza	37
5.6.2	Analisi Empirica e Validazione per Categoria	37
5.7	Vincoli Sperimentali e Limiti del Testbed	39

1. Introduzione

Il presente documento raccoglie i quattro elaborati sviluppati nell'ambito del progetto UniSafe, un sistema di votazione elettronico sicuro pensato per l'ambito universitario. Il lavoro è stato realizzato come progetto d'esame per il corso di *Algoritmi e Protocolli per la Sicurezza* presso l'Università degli Studi di Salerno.

2. WP1 – Modello: Analisi di attori, funzionalità, minacce e contromisure di sicurezza

Il presente work package costituisce la prima analisi delle caratteristiche di un sistema di voto elettronico sicuro per la conduzione di un'elezione in ambito universitario. Nel documento vengono prima discusse le principali tipologie di elezione, analizzandone caratteristiche, vantaggi, svantaggi e compromessi fra sicurezza, integrità e anonimato, al fine di motivare la scelta del modello adottato. Si procede quindi con la definizione degli attori onesti del sistema, specificando ruoli, responsabilità e obiettivi. Vengono poi discussi i possibili avversari interessati a compromettere il sistema, specificando risorse e capacità. Il documento si conclude con l'identificazione delle proprietà di sicurezza che il sistema si prefigge di preservare in presenza di attacchi: autenticità, unicità, segretezza, integrità, verificabilità individuale e verificabilità universale, con esplicitazione dei compromessi adottati e delle assunzioni su cui il modello si basa.

Alcuni riferimenti relativi al funzionamento e ai requisiti di un sistema di voto elettronico sono stati reperiti da fonti pubblicamente disponibili:

- [Linee guida voto elettronico](#)
- [NIST IR 7770](#)
- [ArXiv cs/0108017](#)

Tali fonti hanno orientato la definizione del modello, degli attori coinvolti e della loro separazione.

2.1 Analisi comparativa delle tipologie di elezione

2.1.1 Referendum Binario

Il referendum binario è un modello di votazione utilizzato per approvare o respingere una specifica proposta, delibera o modifica regolamentare. L'elettore può selezionare una sola opzione tra un insieme molto limitato di scelte, tipicamente *Sì* o *No*. In alcuni casi può essere prevista anche l'opzione di scheda bianca.

Vantaggi. Il principale vantaggio è la semplicità. L'interfaccia di voto è immediata, il rischio di errore da parte dell'utente è ridotto e il conteggio finale è particolarmente efficiente. Dal punto di vista crittografico, il dominio dei voti è molto piccolo, rendendo più semplice la validazione della scheda, lo scrutinio e la verifica pubblica del risultato.

Svantaggi. Il modello è poco espressivo: non consente di scegliere tra più candidati o liste e non permette all'elettore di esprimere preferenze graduate o alternative intermedie.

È quindi adatto solo a decisioni binarie, ma non all'elezione di organi rappresentativi complessi.

Implicazioni per il protocollo. È il modello più semplice da implementare in un sistema di voto elettronico sicuro, poiché riduce la complessità della scheda cifrata e del conteggio. Rimangono comunque necessari meccanismi per garantire autenticità, univocità, segretezza, integrità e verificabilità.

2.1.2 Elezione a Lista Chiusa

Il voto a lista chiusa è un modello orientato alla scelta di un gruppo, lista, coalizione o organizzazione. L'elettore esprime un'unica preferenza per una lista nel suo complesso, senza poter selezionare o modificare l'ordine dei candidati al suo interno. L'ordine di elezione dei candidati è quindi stabilito in anticipo dal soggetto che presenta la lista.

Vantaggi. Il modello mantiene una buona semplicità d'uso, poiché l'elettore deve scegliere una sola opzione tra un insieme finito di liste. Anche lo scrutinio risulta relativamente efficiente, perché il sistema deve conteggiare un solo voto per elettore. Inoltre, rispetto al voto nominale, si riduce il rischio che combinazioni particolari di preferenze rendano riconoscibile la scheda.

Svantaggi. L'elettore non può incidere direttamente sulla scelta dei singoli candidati eletti, ma solo sulla lista nel suo complesso. Questo riduce la rappresentatività diretta e concentra maggiore potere decisionale sul gruppo che ha definito l'ordine dei candidati.

Implicazioni per il protocollo. Dal punto di vista crittografico, il voto a lista chiusa rappresenta un compromesso: è più complesso del referendum binario, perché il numero di opzioni può essere maggiore, ma resta più semplice del voto nominale, poiché ogni scheda contiene una sola scelta valida.

2.1.3 Elezione con Preferenza Nominale

Il voto a preferenza nominale consente all'elettore di indicare esplicitamente uno o più candidati specifici. A seconda del regolamento elettorale, la preferenza può essere espressa insieme a una lista oppure indipendentemente da essa. Possono inoltre essere presenti vincoli sul numero massimo di preferenze, sull'appartenenza dei candidati a una lista o su criteri come l'alternanza di genere.

Vantaggi. Offre all'elettore un maggiore controllo sulla composizione dell'organo da eleggere e favorisce un legame più diretto tra elettori ed eletti.

Svantaggi. La procedura di voto è più complessa e richiede maggiore attenzione da parte dell'utente. L'elettore deve conoscere i candidati e rispettare le regole previste dal sistema. Anche lo scrutinio è più oneroso, perché non è sufficiente conteggiare i voti di lista, ma occorre aggregare le preferenze candidato per candidato. Inoltre, combinazioni particolari di preferenze possono aumentare il rischio di riconoscibilità della scheda, con possibili conseguenze sulla segretezza e sulla resistenza alla coercizione.

Implicazioni per il protocollo. È il modello più complesso tra quelli considerati. Il sistema deve verificare che ogni preferenza sia valida, che non siano presenti duplicati, che il numero massimo di preferenze sia rispettato e che eventuali vincoli regolamentari

siano soddisfatti. Questa maggiore espressività comporta un aumento della complessità crittografica, dello scrutinio e della verifica.

2.2 Scelta del Modello

Considerando che le elezioni universitarie prevedono, in genere, l'assegnazione di più ruoli istituzionali distinti, ad esempio Rappresentante al Senato Accademico, Rappresentante nel Consiglio di Amministrazione e Rappresentante del Consiglio Didattico, il modello di votazione più adeguato è quello a **lista chiusa con ruoli predefiniti**. In tale modello, ogni lista rappresenta un insieme di candidati che coprono tutti i ruoli previsti, e l'elettore esprime una singola preferenza selezionando l'intera lista come unità indivisibile. Questa scelta consente di mantenere il processo di voto semplice e strutturato, evitando la complessità tipica del voto a preferenza nominale.

Rispetto al voto nominale, il modello a lista chiusa riduce la superficie di attacco del sistema: l'elettore non può combinare liberamente nominativi appartenenti a liste diverse né esprimere più preferenze individuali, limitando così il numero di configurazioni possibili della scheda, la complessità della validazione del voto e il rischio di schede riconoscibili o di comportamenti coercitivi. Allo stesso tempo, il modello risulta più flessibile rispetto al referendum binario, in quanto consente la candidatura di un numero arbitrario di liste alternative, permettendo una scelta più articolata senza compromettere la semplicità della procedura di voto e del protocollo crittografico sottostante.

2.3 Attori del Sistema

Il sistema prevede quattro attori principali, ciascuno dei quali corrisponde a una componente software in esecuzione su un server dedicato. L'unica eccezione è l'elettore, che interagisce con il sistema tramite un client installato sul proprio dispositivo. Il Sistema di Autenticazione e l'Autorità Elettorale sono intenzionalmente separati: nessuno dei due è in grado, da solo, di correlare l'identità di un elettore con il voto espresso. Il sistema è pensato secondo il principio di *Separation of Privilege*: le funzioni critiche sono distribuite tra componenti software indipendenti in esecuzione su domini isolati. Questo garantisce che la compromissione di un singolo attore non sia sufficiente a violare la segretezza del voto o l'integrità del risultato.

2.3.1 Sistema di Autenticazione (SA)

Ruolo: Gestione dell'identità. **Responsabilità:** gestisce l'elenco degli aventi diritto al voto, verifica le credenziali istituzionali dell'elettore e, in caso di esito positivo, abilita la partecipazione all'elezione, garantendo che ogni elettore possa accedervi una sola volta. **Vincoli:** non ha accesso all'urna elettronica né alle schede di voto. Una volta rilasciato il token, non riceve alcuna informazione su se o come l'elettore parteciperà al voto.

2.3.2 Autorità Elettorale (AE)

Ruolo: Gestore dell'urna e dello scrutinio. **Responsabilità:** riceve le schede cifrate, ne verifica la validità crittografica e le registra su un registro pubblico. Al termine della raccolta, esegue lo scrutinio e pubblica il risultato corredato delle relative prove.

Vincoli: non riceve informazioni sull'identità degli elettori; l'unica garanzia che possiede è che ogni scheda è accompagnata da un token rilasciato dal SA.

2.3.3 Client dell'Elettore

Ruolo: Interfaccia utente e nodo crittografico. **Responsabilità:** è il software in esecuzione sul dispositivo dell'elettore. Si autentica presso il SA, prepara la scheda cifrata e la trasmette all'AE. Conserva localmente i dati necessari per la verifica individuale del proprio voto. **Vincoli:** fornisce all'elettore una ricevuta per la futura verifica del voto, senza richiedere competenze tecniche da parte dell'utente.

2.3.4 Osservatore Pubblico

Ruolo: Garante della verificabilità universale. **Responsabilità:** è qualsiasi client che acceda al registro pubblico dell'AE per verificare la correttezza del risultato, senza necessità di essere un elettore registrato. **Vincoli:** non possiede alcun privilegio di scrittura o modifica.

2.4 Funzionalità del Sistema

Il sistema ha lo scopo di condurre un'elezione elettronica a lista chiusa articolata in quattro fasi sequenziali.

1. **Inizializzazione:** il SA pubblica la lista degli aventi diritto al voto; l'AE pubblica la lista dei candidati, i parametri crittografici del sistema e le chiavi pubbliche necessarie; vengono definiti e resi pubblici i parametri temporali di apertura e chiusura delle urne.
2. **Registrazione e autenticazione:** ciascun elettore si autentica presso il SA tramite le proprie credenziali; il SA verifica l'identità dell'elettore, controlla che non abbia già ricevuto credenziali di voto e rilascia un token crittografico firmato.
3. **Votazione:** l'elettore prepara la scheda di voto selezionando una delle liste, la cifra e la arricchisce con le prove crittografiche necessarie. L'elettore invia la scheda all'AE, che la verifica e la registra nel registro pubblico; l'elettore riceve una ricevuta che gli permetterà di verificare l'inclusione del proprio voto.
4. **Scrutinio e pubblicazione:** al termine della raccolta, l'AE decifra i voti e pubblica il risultato. Vengono pubblicate le prove crittografiche necessarie per la verifica universale; ciascun elettore può verificare individualmente l'inclusione del proprio voto.

2.5 Threat Model

In questa sezione si identificano i possibili avversari del sistema, le loro risorse e capacità, e gli obiettivi che potrebbero perseguire. Il threat model è organizzato per categoria di avversario.

2.5.1 Gestore Disonesto del Server (AE o SA corrotta)

Un attore interno al sistema che agisce in modo malevolo o è stato compromesso da un avversario esterno.

Risorse e capacità: accesso diretto ai database del sistema, inclusi registro dei voti e log di autenticazione; conoscenza dei parametri di sistema, incluse eventuali chiavi private del gestore; capacità di modificare, eliminare o inserire record nel registro.

Obiettivi potenziali: alterazione del conteggio, modificando o sopprimendo schede di voto già registrate per favorire un candidato; violazione della segretezza, correlando le schede cifrate alle identità reali degli elettori sfruttando i log dell'SA in combinazione con i dati dell'AE; inserimento di schede fraudolente; impedimento della pubblicazione del risultato o pubblicazione di un risultato falso.

2.5.2 Elettore Malevolo

Un elettore legittimamente registrato che tenta di sfruttare il sistema per ottenere vantaggi illeciti o per perturbarne il corretto funzionamento.

Risorse e capacità: accesso a un'istanza legittima del client di voto; possesso delle proprie credenziali crittografiche; capacità di intercettare o analizzare il traffico di rete verso l'AE; possibile collaborazione con terzi, ad esempio acquirenti di voto.

Obiettivi potenziali: tentativo di votare più di una volta, riutilizzando le credenziali o inviando più schede cifrate differenti; dimostrazione a un terzo di come si è votato, per ottenere un compenso o per essere esonerato da una minaccia; negazione di aver espresso un certo voto o di aver partecipato all'elezione; invio di schede non valide in numero elevato per saturare il sistema o introdurre rumore nel registro pubblico.

2.5.3 Avversario Esterno Passivo (Eavesdropper)

Un soggetto esterno al sistema che monitora passivamente le comunicazioni tra gli attori, senza poterle modificare.

Risorse e capacità: capacità di intercettare il traffico di rete, ad esempio su reti non cifrate o tramite attacchi MitM a livello di trasporto; accesso al registro pubblico delle schede cifrate; capacità di analisi statistica e correlazione temporale.

Obiettivi potenziali: correlare l'invio di una scheda cifrata con l'identità dell'elettore tramite analisi del traffico; dedurre il contenuto della scheda da informazioni ausiliarie, come dimensione del messaggio o metadati.

2.5.4 Avversario Esterno Attivo

Un soggetto esterno che non si limita a osservare ma interviene attivamente sulle comunicazioni o sull'infrastruttura del sistema.

Risorse e capacità: capacità di modificare, ritardare o eliminare messaggi in transito tramite attacchi MitM; capacità di lanciare attacchi replay; eventuale compromissione parziale dell'infrastruttura di rete; capacità di sovraccaricare i server del sistema tramite attacchi di massa per renderli indisponibili.

Obiettivi potenziali: impedire a specifici elettori di far giungere il proprio voto all'AE; re-inviare una scheda già registrata per causare duplicati o confusione nel sistema; modificare una scheda in transito, alterando il voto prima che raggiunga l'AE; attacco alla disponibilità del servizio tramite DDoS contro SA o AE durante la fase

di votazione, oppure contro lo scrutinio o la pubblicazione, impedendo la verifica del risultato.

2.6 Proprietà di Sicurezza

In questa sezione si definiscono le proprietà di sicurezza che il sistema si prefigge di garantire.

2.6.1 Autenticità

Solo gli elettori legittimamente registrati, la cui identità è stata verificata dall'SA, possono partecipare al voto. Formalmente, nessuna scheda di voto valida può essere introdotta nel sistema da un soggetto non presente nella lista degli aventi diritto.

Condizioni di garanzia: la proprietà è garantita a patto che il meccanismo di rilascio delle credenziali da parte dell'SA sia sicuro e che le credenziali non siano trasferibili o falsificabili. Si assume che le primitive crittografiche utilizzate, come firme digitali e MAC, siano computazionalmente sicure.

2.6.2 Unicità del Voto (One Voter, One Vote)

Ciascun elettore può esprimere al più un voto valido. Il sistema deve prevenire sia il *double voting* intenzionale da parte di un elettore sia la duplicazione di voti da parte di un gestore corrotto.

Condizioni di garanzia: questa proprietà richiede che le credenziali di voto siano a uso singolo e non riutilizzabili, e che il registro delle schede accettate sia verificabile pubblicamente. Un gestore corrotto non deve poter introdurre una seconda scheda valida per lo stesso elettore senza che ciò sia rilevabile.

2.6.3 Segretezza del Voto (Vote Privacy)

Nessuna singola entità deve essere in grado di associare l'identità reale di un elettore alla sua preferenza espressa. Il sistema garantisce il pseudoanonimato: ogni scheda nel registro è riconducibile a un elettore autorizzato, ma non a uno specifico elettore identificabile.

Condizioni di garanzia: questa proprietà è garantita a patto che il canale tra l'elettore e l'AE non consenta la correlazione delle schede alle identità.

2.6.4 Integrità dei Voti

I voti registrati nel sistema non devono poter essere alterati, soppressi o introdotti fraudolentemente dopo la loro espressione. Questa proprietà si declina in due sotto-proprietà: *integrità individuale*, cioè il voto di un elettore non può essere modificato dopo la sua registrazione né dall'AE né da un avversario esterno, e *integrità del registro*, cioè il registro pubblico delle schede cifrate è immutabile e qualsiasi modifica è rilevabile da chiunque.

Condizioni di garanzia: l'integrità è garantita tramite l'uso di strutture dati con proprietà di non-ripudiabilità e tramite la pubblicazione del registro su canali verificabili. Si assume che le primitive crittografiche di hash e firma siano sicure.

2.6.5 Verificabilità Individuale

Ciascun elettore deve poter verificare autonomamente che il proprio voto sia stato correttamente incluso nel conteggio finale. A tal fine, l'elettore riceve una ricevuta al momento della registrazione della propria scheda.

Condizioni di garanzia: la verifica individuale è possibile a patto che l'elettore conservi la ricevuta ricevuta dall'AE e che il registro pubblico sia accessibile.

2.6.6 Verificabilità Universale

Chiunque, inclusi soggetti non registrati come elettori, deve poter verificare la correttezza del risultato finale dell'elezione. Ciò significa che il processo di scrutinio deve essere pubblicamente auditabile: dato il registro pubblico delle schede cifrate e le prove pubblicate dall'AE, chiunque deve poter confermare che il risultato è stato calcolato correttamente.

Condizioni di garanzia: questa proprietà richiede che l'AE pubblichi, insieme al risultato, una prova crittografica della correttezza del conteggio, costruita in modo tale che nessun avversario possa produrre una prova valida per un risultato falso.

2.6.7 Proprietà non pienamente garantite e compromessi

Il sistema non è in grado di garantire incondizionatamente tutte le proprietà elencate. Si dichiarano esplicitamente i seguenti limiti e compromessi:

- **Segretezza vs. verificabilità individuale:** la ricevuta consegnata all'elettore permette di verificare l'inclusione del proprio voto, ma non ne rivela il contenuto. Tuttavia, un elettore potrebbe conservare informazioni sufficienti a dimostrare la propria scelta a un terzo, rendendo possibile la coercizione o la vendita del voto. Questa limitazione è un compromesso dichiarato; soluzioni più robuste richiederebbero strumenti crittografici avanzati non trattati nel corso e sono indicate come possibili estensioni future.
- **Segretezza condizionata alla non-collusione:** la segretezza del voto è garantita solo se SA e AE non colludono. In caso di collusione, è teoricamente possibile correlare i log di autenticazione con le schede cifrate. Questo rischio residuo è mitigato dalla separazione tra i due componenti, ma non eliminato crittograficamente.
- **Anonimato a livello di rete:** il protocollo non opera a livello di trasporto e non garantisce quindi l'anonimato della connessione. Un avversario in grado di osservare il traffico di rete potrebbe correlare l'invio di una scheda all'identità dell'elettore tramite l'indirizzo IP o l'orario di connessione. Si assume l'utilizzo di un canale cifrato; tecniche di anonimizzazione della rete sono al di fuori dello scope di questo progetto.
- **Disponibilità del servizio:** il sistema non può garantire la disponibilità del servizio in presenza di attacchi di negazione del servizio, ma adotta comunque delle misure di mitigazione a livello applicativo, descritte più in dettaglio nel WP2.

2.7 Analisi dell'Efficienza e Scalabilità (Qualitativa)

In questa sezione vengono analizzati i requisiti di efficienza, latenza e scalabilità del sistema adottando una prospettiva qualitativa, coerente con il ruolo del WP1. In accordo con la crittografia moderna, la sicurezza del protocollo è valutata rispetto ad avversari computazionalmente limitati; di conseguenza, le garanzie di sicurezza devono essere bilanciate con la praticabilità del sistema. Meccanismi e protocolli eccessivamente complessi o fortemente interattivi, pur potendo risultare formalmente corretti, rischiano infatti di essere inadeguati in un contesto reale.

Seguendo i principi di *Economy of Mechanism* e *Open Design*, il sistema privilegia soluzioni semplici, modulari e facilmente analizzabili. La riduzione della complessità non rappresenta solo un obiettivo di efficienza, ma una scelta progettuale che aumenta l'affidabilità complessiva del sistema, limitando il rischio di errori implementativi e facilitando l'analisi delle proprietà di sicurezza.

2.7.1 Efficienza Computazionale

L'efficienza computazionale viene considerata già in fase di modello, poiché l'adozione di meccanismi crittografici comporta inevitabilmente un costo in termini di calcolo, memoria e comunicazione. In linea con la letteratura di riferimento, ogni attore del sistema è progettato per eseguire esclusivamente le operazioni necessarie al proprio ruolo, evitando sovrapposizioni funzionali e colli di bottiglia.

Lato client (elettore): il client dell'elettore deve eseguire un numero limitato di operazioni crittografiche, compatibili con dispositivi consumer come smartphone e laptop. La preparazione della scheda può includere la cifratura del voto e, se previsto dal protocollo, la produzione di una prova crittografica di validità. Tali operazioni devono rimanere sufficientemente leggere da non compromettere la fruibilità del sistema. La scelta di un modello a lista chiusa contribuisce a questo obiettivo, poiché ogni scheda rappresenta una singola alternativa valida all'interno di un insieme finito di liste.

Lato server (Autorità Elettorale): l'Autorità Elettorale è responsabile della registrazione delle schede, della verifica della loro validità e dello scrutinio finale. Rispetto a un sistema a preferenza nominale, il modello a lista chiusa riduce la complessità delle operazioni di controllo e aggregazione, evitando la gestione di combinazioni multiple di preferenze. Il carico computazionale dell'AE cresce quindi in modo proporzionale al numero di voti ricevuti, risultando adeguato allo scenario di un'elezione universitaria.

2.7.2 Latenza e User Experience

La latenza percepita dall'utente è un fattore determinante per l'accettabilità pratica del sistema. Anche protocolli dotati di solide garanzie formali possono risultare inefficaci se l'interazione richiesta è lenta o complessa. Per questo motivo, il protocollo è progettato per limitare il numero di interazioni e ridurre i tempi di risposta, senza indebolire le proprietà di sicurezza.

In particolare, la fase di autenticazione deve richiedere un numero minimo di scambi di messaggi tra elettore e SA; l'invio della scheda cifrata deve avvenire con pochi round di comunicazione tra client e AE; l'elettore deve ricevere una conferma rapida e verificabile dell'avvenuta registrazione del voto, a supporto della verificabilità individuale. Nel

complesso, la progettazione privilegia protocolli a bassa interattività e con tempi di risposta prevedibili, bilanciando sicurezza formale e *Psychological Acceptability*.

2.7.3 Scalabilità del Sistema

Il sistema deve essere in grado di gestire un numero elevato di elettori e carichi non uniformi, tipici delle elezioni universitarie, in cui si osservano picchi di accesso in prossimità dell'apertura o della chiusura delle urne.

La separazione delle responsabilità tra SA e AE consente di scalare orizzontalmente i componenti in modo indipendente, intervenendo sui colli di bottiglia senza compromettere l'intero sistema. Inoltre, l'adozione del modello a lista chiusa mantiene contenute e costanti le dimensioni delle schede cifrate, facilitando la gestione del registro dei voti e le operazioni di pubblicazione e verifica.

2.7.4 Semplicità e Manutenibilità (Open Design)

In accordo con il principio di *Open Design*, l'architettura del sistema è progettata per essere semplice, trasparente e facilmente ispezionabile. In un sistema di voto elettronico, la semplicità non rappresenta solo una scelta ingegneristica, ma un requisito di sicurezza: meccanismi complessi aumentano la superficie di errore implementativo e rendono più difficile individuare vulnerabilità o comportamenti scorretti.

Di conseguenza, il sistema privilegia componenti ben separati, interfacce chiare e un flusso di esecuzione facilmente comprensibile. Questo approccio consente audit di sicurezza più efficaci e riproducibili, una manutenzione più agevole nel tempo e un ripristino più rapido in caso di guasti o incidenti, migliorando complessivamente la disponibilità del servizio.

In sintesi, l'adozione di un design aperto e minimale rappresenta una scelta consapevole per garantire che le proprietà di sicurezza definite nel modello possano essere effettivamente mantenute anche durante l'evoluzione e l'uso operativo del sistema.

3. WP2 – Soluzione: Protocollo di Voto Elettronico

Dato il modello concettuale definito nel WP1, questo work package presenta il protocollo crittografico progettato per il sistema di votazione elettronica sicura. L'obiettivo è tradurre i requisiti di sicurezza in un flusso operativo concreto.

Il protocollo si articola in cinque fasi sequenziali gestite automaticamente dal sistema, riducendo al minimo l'intervento umano alla sola configurazione iniziale:

1. **Inizializzazione:** configurazione dei parametri elettorali (liste, aventi diritto, vincoli temporali) e generazione delle chiavi.
2. **Autenticazione:** verifica dell'identità dell'elettore presso il SA e rilascio del token di voto.
3. **Votazione:** cifratura della scheda da parte del client e trasmissione all'AE.
4. **Scrutinio:** decifratura massiva dei voti, calcolo dei risultati e pubblicazione delle prove di correttezza.
5. **Verifica individuale e universale:** procedure per il controllo della correttezza del processo.

Le primitive crittografiche adottate sono:

- **Segretezza e integrità:** RSA-OAEP (cifratura probabilistica) e RSA-PSS con SHA-256 (firme digitali).
- **Sicurezza in transito:** canali cifrati TLS obbligatori per qualsiasi comunicazione tra gli attori.
- **Trasparenza e verificabilità:** registro pubblico append-only (*Bulletin Board*) basato su struttura Merkle Tree.

Nelle sezioni successive vengono dettagliati l'architettura dei messaggi, la struttura dei dati del registro e il flusso delle interazioni tra gli attori.

3.1 Fase 1 – Inizializzazione

L'amministratore svolge un ruolo puramente configurativo. Vengono definiti e resi pubblici sul registro prima dell'apertura delle urne:

- l'elenco delle liste candidate, ciascuna identificata da un indice univoco;
- i parametri temporali dell'elezione (apertura e chiusura delle urne);
- le chiavi pubbliche di SA e AE;
- l'informativa con i criteri di accesso per gli aventi diritto al voto.

Tutti i parametri di inizializzazione vengono pubblicati sul registro prima dell'apertura delle urne, in modo da rendere verificabile da chiunque il contesto dell'elezione e impedire modifiche silenziose a elezione avviata. L'autenticità di tali parametri è garantita in fase di distribuzione iniziale tramite certificati X.509 su canali TLS.

A configurazione completata, l'amministratore non interviene più nel processo: il sistema passa in modalità di esecuzione automatica, vincolata ai parametri pubblicati,

riducendo la superficie di attacco e il grado di fiducia richiesto verso il gestore del sistema.

3.1.1 Generazione e distribuzione delle chiavi

Il **Sistema di Autenticazione (SA)** genera una coppia RSA dedicata esclusivamente alla firma dei token; la chiave privata rimane isolata nel dominio del SA, la pubblica è sul registro.

L'**Autorità Elettorale (AE)** genera due coppie indipendenti:

- **Coppia di cifratura (RSA-OAEP):** la chiave pubblica è distribuita ai client per la cifratura delle schede; la privata è caricata in memoria dall'AE *esclusivamente a urne chiuse*, nella fase di scrutinio.
- **Coppia di firma (RSA-PSS):** la chiave privata firma ricevute, blocchi del registro e il verbale di scrutinio; la pubblica, pubblicata prima dell'apertura, consente la verifica universale.

Tutte le chiavi pubbliche sono rese disponibili sul registro prima dell'apertura delle urne. La loro autenticità è garantita tramite certificati X.509 distribuiti su canali TLS.

3.2 Fase 2 – Autenticazione e Rilascio del Token

La fase consente di verificare che l'utente sia un elettore avente diritto e di rilasciargli una credenziale crittografica a uso singolo. Essa è gestita esclusivamente dal SA, che opera separatamente dall'AE: il SA verifica l'identità e il diritto di voto dell'elettore, ma non riceve né elabora la scheda. Il token è trattato dall'AE come identificatore opaco e non contiene informazioni identificative o riferimenti alla scelta dell'elettore; il suo unico scopo è attestare che il soggetto che lo presenta è stato autorizzato dal SA a partecipare all'elezione.

1. L'elettore si autentica presso il SA tramite credenziali istituzionali su canale TLS.
2. Il SA verifica che all'elettore non sia già stato rilasciato un token.
3. Il SA genera un token contenente l'identificativo dell'elezione e un nonce casuale.
4. Il SA firma il token con RSA-PSS su SHA-256.
5. Il SA registra internamente l'avvenuto rilascio e restituisce il token firmato al client. Da questo momento il SA non ha più alcun ruolo nel processo: il client conserva il token e lo presenterà autonomamente all'AE nella fase di votazione.
6. Il SA applica un rate limiting per mitigare attacchi volumetrici; il token include una finestra di validità temporale (30 minuti), così da limitare l'utilità di token ottenuti in massa in anticipo.

3.2.1 Politica di scadenza (Use-it-or-Lose-it)

- **Finestra temporale limitata:** la validità operativa del token è circoscritta a un intervallo prefissato e ridotto (30 minuti).

- **Unicità ed esclusione del rinnovo:** emesso il token, il SA inibisce qualsiasi ulteriore tentativo di autenticazione per lo stesso elettore; non sono ammessi meccanismi di refresh token o ripristino della sessione.
- **Perenzione per inutilizzo:** se il token non viene presentato all'AE entro i limiti temporali, decade irreversibilmente. Durante le verifiche della Fase 3, l'AE rigetterà la richiesta con un errore di validazione.

3.3 Fase 3 – Votazione

3.3.1 Preparazione della scheda

Il client mappa la scelta dell'elettore come indice intero della lista selezionata. Prima di cifrare, genera un **seed** casuale tramite `os.urandom`. Il voto viene cifrato con la chiave pubblica dell'AE mediante RSA-OAEP con quel seed; il seed stesso viene cifrato separatamente con la stessa chiave pubblica. Il messaggio inviato all'AE contiene:

- $\text{Enc_1} = \text{RSA-OAEP}(\text{voto} \parallel \text{seed}, k_{\text{pub,AE}})$
- $\text{Enc_2} = \text{RSA-OAEP}(\text{seed}, k_{\text{pub,AE}})$
- il token firmato dal SA
- il nonce della Proof of Work

A urne chiuse, l'AE decifra **Enc_2** per recuperare il seed in chiaro e lo pubblica insieme al voto. Chiunque può allora rieseguire $\text{RSA-OAEP}(\text{voto} \parallel \text{seed}, k_{\text{pub,AE}})$ e confrontare il risultato con la scheda registrata nel Merkle Tree, verificando che l'AE non abbia alterato né inventato alcuna decifrazione.

L'identificativo dell'elettore non viene incluso nel messaggio.

3.3.2 Proof of Work Adattiva Globale

Prima dell'invio, il client risolve una PoW calcolando un nonce tale che

$$\text{SHA-256}(\text{Enc_1} \parallel \text{nonce})$$

presenti un numero prefissato di bit iniziali a zero. Questo meccanismo, basato su funzioni hash crittografiche, rende oneroso l'invio massivo di richieste automatizzate e mitiga gli attacchi volumetrici contro l'AE.

La difficoltà è modulata dinamicamente:

- **Operatività standard:** difficoltà minima, calcolo $\approx 0,1$ s.
- **Sotto attacco (DoS):** la difficoltà viene incrementata automaticamente, innalzando il costo per la botnet senza penalizzare eccessivamente l'elettore onesto (ritardo percepito $\approx 2-3$ s).

3.3.3 Verifiche dell'AE e registrazione

All'atto della ricezione, l'AE verifica sequenzialmente:

1. validità matematica della PoW;

2. validità della firma del token tramite $k_{\text{pub,SA}}$;
3. unicità del token (non presente in `used_tokens`);
4. validità temporale del token (finestra < 30 min).

In caso di esito positivo, la scheda viene accettata, il token marcato come usato, e un record `[Enc_1, Enc_2, indice, timestamp]` viene inserito come nuova foglia nel Merkle Tree. L'hash SHA-256 del record costituisce la foglia dell'urna; grazie alla struttura Merkle, qualsiasi tentativo di alterare una scheda già registrata invalida i nodi superiori, rendendo la manomissione rilevabile pubblicamente.

3.3.4 Ricevuta crittografica

L'AE firma con RSA-PSS e restituisce al client una ricevuta contenente:

- l'indice della foglia nel Merkle Tree;
- la scheda cifrata (`Enc_1`);
- la Merkle proof di inclusione.

Alla chiusura delle urne, l'AE pubblica e firma la radice finale del Merkle Tree.

Una volta registrata, la scheda è definitiva e non può essere sostituita o annullata.

3.4 Fase 4 – Scrutinio e Pubblicazione

Alla chiusura delle urne, l'AE avvia automaticamente lo scrutinio operando sullo stato finale del registro, vincolato dalla radice del Merkle Tree pubblicata in fase di votazione. La chiave privata di decifratura ($k_{\text{priv,AE}}$) viene istanziata in memoria *unicamente* all'invocazione dell'endpoint `/close`.

Per ogni record nel registro:

1. decifratura del seed: `seed = RSA-OAEP-1(Enc_2,  $k_{\text{priv,AE}}$ )`;
2. decifratura del voto: `voto = RSA-OAEP-1(Enc_1,  $k_{\text{priv,AE}}$ )`;
3. validazione di congruenza: ricifratura locale di (`voto`, `seed`) e confronto con `Enc_1`; incongruenza $\Rightarrow$ declassamento a *Scheda Nulla*.

Al termine, l'AE pubblica sul registro:

- il risultato finale aggregato per ciascuna lista;
- l'insieme completo delle triple (`Enc_1`, `voto`, `seed`) per ciascuna scheda scrutinata (la pubblicazione del seed avviene solo in questa fase).

I voti in chiaro vengono aggregati per lista candidata. Le schede non conformi al dominio dei voti validi sono conteggiate come schede nulle, senza compromettere l'integrità del registro.

3.5 Fase 5 – Verifica Individuale e Universale

3.5.1 Verifica individuale

Tramite la ricevuta e le chiavi pubbliche dell'AE, ciascun elettore verifica che:

1. la firma RSA-PSS sulla ricevuta sia valida;
2. la Merkle proof sia coerente con la radice finale pubblicata;
3. la propria **Enc_1** compaia nel registro pubblico abbinata al voto in chiaro corretto, coerentemente con la ricevuta ricevuta dall'AE, e sia verificabile rieseguendo la cifratura con il seed pubblicato.

3.5.2 Verifica universale

Chiunque verifica che:

1. la firma dell'AE sulla radice del Merkle Tree finale sia valida;
2. lo scrutinio utilizzi esclusivamente schede incluse nel registro;
3. l'aggregazione pubblicata sia coerente con le triple disponibili.

3.6 Limiti Dichiarati del Sistema

- **Segretezza durante la raccolta:** non è garantito crittograficamente che l'AE non decifri le schede prima della chiusura; la protezione è affidata a vincoli operativi.
- **Receipt-freeness:** la verificabilità individuale consente, a scrutinio concluso, di dimostrare a terzi il contenuto del proprio voto.
- **Anonimato condizionato:** la segretezza regge solo se SA e AE non colludono.
- **Omissione di schede:** il Merkle Tree impedisce alterazioni retroattive ma non l'omissione al momento della ricezione; tale evento è rilevabile solo tramite la ricevuta individuale.
- **Integrità del client:** un client compromesso può produrre schede non coerenti con la scelta effettuata.

4. WP3 – Analisi della Sicurezza

Il presente work package ha lo scopo di analizzare la sicurezza della soluzione crittografica definita in WP2 rispetto al modello concettuale introdotto in WP1. L'analisi si articola in tre parti complementari:

- Nella prima parte viene condotta una verifica sistematica delle proprietà di sicurezza: per ciascuna delle sei proprietà identificate nel modello (autenticità, unicità, segretezza, integrità, verificabilità individuale e verificabilità universale) si esamina il meccanismo del protocollo che la implementa, le condizioni sotto cui la garanzia regge e i casi in cui essa risulta parziale o condizionata.
- Nella seconda parte si analizza il threat model del WP1 dal punto di vista del protocollo: per ciascuna categoria di avversario si valuta se le contromisure adottate in WP2 siano sufficienti a neutralizzarne le capacità offensive, evidenziando eventuali gap residui.
- Nella terza parte vengono identificate e motivate modifiche migliorative al protocollo: interventi che apportano benefici netti a una o più proprietà di sicurezza senza introdurre perdite in altre, compatibili con i vincoli di complessità e scalabilità dichiarati in WP1.

4.1 Verifica delle Proprietà di Sicurezza

In questa sezione ciascuna proprietà di sicurezza definita in WP1 viene analizzata rispetto al protocollo di WP2, esaminando i meccanismi che la supportano, le condizioni necessarie alla sua tenuta e i limiti residui.

4.1.1 Autenticità

Proprietà attesa (WP1): solo gli elettori legittimamente registrati possono partecipare al voto; nessuna scheda valida può essere introdotta da un soggetto non autorizzato.

Meccanismi nel protocollo (WP2):

- Il Sistema di Autenticazione (SA) verifica le credenziali istituzionali dell'elettore prima di rilasciare qualsiasi token.
- Il token è firmato crittograficamente dal SA con schema RSA-PSS su hash SHA-256.
- L'Autorità Elettorale (AE) verifica la firma del token per ciascuna scheda ricevuta, rifiutando ogni scheda priva di token valido.
- Il token include un nonce casuale non predicibile, che ne impedisce la falsificazione e riduce la possibilità di correlazioni tra token distinti.

Condizioni di validità: la garanzia regge se le primitive crittografiche (RSA-PSS, SHA-256) sono computazionalmente sicure, se la chiave privata del SA non è compromessa e se il canale TLS tra elettore e SA non è soggetto ad attacchi attivi che consentano di sostituire le credenziali.

Limiti residui: un elettore legittimo le cui credenziali istituzionali siano state sottratte da un avversario potrebbe consentire a quest'ultimo di ottenere un token valido. Questa minaccia è esterna al perimetro del protocollo e dipende dalla robustezza del sistema di identità istituzionale.

4.1.2 Unicità del Voto (One Voter, One Vote)

Proprietà attesa (WP1): ciascun elettore può esprimere al più un voto valido; il sistema deve prevenire sia il double voting intenzionale sia la duplicazione di voti da parte di un gestore corrotto.

Meccanismi nel protocollo (WP2):

- Il SA controlla che a ciascun elettore sia rilasciato un unico token per elezione; i tentativi successivi di autenticazione non producono nuovi token.
- L'AE verifica l'unicità del token al momento della ricezione della scheda: un token già marcato come usato causa il rifiuto immediato della richiesta.
- Il Merkle Tree del registro è append-only: ogni scheda accettata è associata a un indice progressivo univoco, e la struttura impedisce l'inserimento retroattivo di schede duplicate senza invalidare la radice pubblicata.

Condizioni di validità: la garanzia regge se la chiave privata del SA non è compromessa (condizione necessaria affinché i token non siano falsificabili da un avversario esterno) e se SA e AE non colludono (condizione necessaria affinché i token non vengano emessi o accettati in modo fraudolento al di fuori del flusso previsto dal protocollo). Un avversario esterno privo di token firmati dal SA non può inserire schede valide nel registro, indipendentemente dalle proprie capacità computazionali.

Limiti residui: il protocollo non prevede un meccanismo pubblico e verificabile che attesti che il numero di schede nel registro non superi il numero di token legittimamente emessi dal SA. In assenza di tale meccanismo, un'eventuale collusione SA-AE che producesse schede in eccesso rispetto agli elettori autenticati non sarebbe rilevabile da un osservatore esterno. Questo gap è affrontato come modifica migliorativa nella Sezione 4.3.1, dove si propone che il SA pubblichi e firmi il conteggio dei token emessi a urne chiuse, consentendo a chiunque di verificare che il numero di schede nel registro non lo superi. Si noti che una discrepanza in difetto ovvero un numero di schede inferiore ai token emessi è un comportamento del tutto legittimo, poiché un elettore può autenticarsi e ottenere un token senza poi esercitare il proprio diritto di voto.

4.1.3 Segretezza del Voto (Vote Privacy)

Proprietà attesa (WP1): nessuna singola entità può associare l'identità reale di un elettore alla sua preferenza espressa.

Meccanismi nel protocollo (WP2):

- La scheda viene cifrata con RSA-OAEP usando la chiave pubblica dell'AE: solo l'AE, a urne chiuse, può decifrarla.

- La cifratura probabilistica tramite seed casuale garantisce che schede con voto identico producano ciphertext completamente diversi, impedendo la correlazione per confronto.
- Il messaggio inviato all'AE non contiene identificativi dell'elettore: l'AE riceve esclusivamente la scheda cifrata, il seed cifrato, il token opaco e il nonce PoW.
- La separazione funzionale tra SA (che conosce l'identità) e AE (che conosce la scheda) è il principale meccanismo strutturale di protezione della segretezza.

Condizioni di validità: la segretezza è garantita a condizione che SA e AE non colludano e che il canale di comunicazione tra client e AE non consenta la correlazione delle schede alle identità tramite analisi del traffico di rete.

Limiti residui: in caso di collusione tra SA e AE, è teoricamente possibile correlare i log di autenticazione con i record del registro tramite analisi temporale.

4.1.4 Integrità dei Voti

Proprietà attesa (WP1): i voti registrati non possono essere alterati, soppressi o introdotti fraudolentemente dopo la loro espressione.

Meccanismi nel protocollo (WP2):

- Il registro delle schede è strutturato come un Merkle Tree append-only: ogni scheda accettata costituisce una foglia, e la radice viene pubblicata e firmata dall'AE a urne chiuse.
- Qualsiasi modifica retroattiva a una scheda già registrata invalida tutti i nodi superiori del Merkle Tree, rendendo la manomissione rilevabile pubblicamente dal confronto con la radice firmata.
- La ricevuta rilasciata all'elettore contiene la Merkle proof della propria scheda: ciascun elettore può autonomamente verificare l'inclusione nella radice finale pubblicata.
- Lo scrutinio opera sullo stato finale del registro vincolato dalla radice firmata: l'AE non può alterare l'insieme di schede da scrutinare senza invalidare la propria firma.

Condizioni di validità: l'integrità è garantita se le primitive crittografiche (SHA-256 per il Merkle Tree, RSA-PSS per la firma sulla radice) sono sicure e se la chiave privata di firma dell'AE non è compromessa.

Limiti residui: il Merkle Tree impedisce alterazioni retroattive ma non l'omissione di una scheda al momento della ricezione, prima che essa venga inserita nel registro. Tale omissione è rilevabile solo dall'elettore tramite la propria ricevuta, e solo se l'elettore effettua attivamente la verifica individuale.

4.1.5 Verificabilità Individuale

Proprietà attesa (WP1): ciascun elettore può verificare autonomamente che il proprio voto sia stato correttamente incluso nel conteggio finale.

Meccanismi nel protocollo (WP2):

- L'AE rilascia all'elettore una ricevuta firmata con RSA-PSS contenente l'indice della foglia nel Merkle Tree, la scheda cifrata e la Merkle proof di inclusione.
- L'elettore verifica la firma sulla ricevuta tramite la chiave pubblica di firma dell'AE, pubblicata sul registro in fase di inizializzazione.
- L'elettore verifica la Merkle proof confrontandola con la radice finale pubblicata dall'AE a urne chiuse.
- A scrutinio concluso, l'elettore individua nel registro pubblico la tripla (scheda cifrata, voto in chiaro, seed) corrispondente alla propria scheda e verifica la correttezza della decifratura rieseguendo la cifratura con il seed pubblicato.

Condizioni di validità: la verifica individuale è possibile se l'elettore conserva la ricevuta e se il registro pubblico è accessibile. La proprietà dipende inoltre dall'autenticità della chiave pubblica di firma dell'AE, distribuita tramite certificati X.509 su canale TLS.

Limiti residui: la ricevuta consente a un elettore di dimostrare a terzi il contenuto del proprio voto a scrutinio concluso (receipt-freeness non garantita), rendendo possibile la coercizione o la vendita del voto. Questo compromesso è dichiarato in WP2 e motivato dalla scelta di privilegiare la verificabilità individuale.

4.1.6 Verificabilità Universale

Proprietà attesa (WP1): chiunque, inclusi soggetti non registrati come elettori, può verificare la correttezza del risultato finale dell'elezione.

Meccanismi nel protocollo (WP2):

- L'AE pubblica la radice del Merkle Tree finale firmata, il risultato aggregato per lista e l'insieme completo delle triple (scheda cifrata, voto in chiaro, seed) per ciascuna scheda scrutinata.
- Chiunque può verificare la firma dell'AE sulla radice e sul verbale dello scrutinio tramite la chiave pubblica pubblicata in fase di inizializzazione.
- Chiunque può rieseguire la cifratura di ogni voto in chiaro con il seed pubblicato e confrontare il risultato con la scheda cifrata nel registro, verificando che l'AE non abbia alterato né inventato alcuna decifratura.
- Chiunque può verificare che l'aggregazione dei voti pubblicata sia coerente con l'insieme delle triple disponibili.

Condizioni di validità: la verificabilità universale regge se la firma dell'AE è autentica e se il registro pubblico è accessibile. La pubblicazione del seed avviene solo a scrutinio concluso, preservando la segretezza durante la raccolta.

Limiti residui: la verificabilità universale garantisce la coerenza interna del registro pubblico: chiunque può verificare che il risultato sia calcolato correttamente sulle schede presenti. Tuttavia, un osservatore esterno non dispone di strumenti per

verificare che il registro sia completo, ovvero che l'AE non abbia omesso schede legittime prima del loro inserimento. Questa forma di omissione è rilevabile solo individualmente, da ciascun elettore tramite la propria ricevuta, e non universalmente. La verificabilità universale è quindi piena sulla correttezza del conteggio, ma parziale sulla completezza dell'insieme delle schede scrutinate.

4.1.7 Riepilogo della Verifica

La tabella 1 riassume l'esito della verifica per ciascuna proprietà di sicurezza.

Proprietà	Meccanismo principale	Garanzia	Limite residuo
Autenticità	Token SA firmato RSA-PSS, verifica AE	Forte (cond. sicurezza SA)	Furto credenziali istituzionali (fuori scope)
Unicità	Token a uso singolo, Merkle Tree append-only	Forte (cond. integrità SA e AE)	Assenza riconciliazione pubblica SA-AE
Segretezza	RSA-OAEP probabilistico, separazione SA/AE	Condizionata (non-collusione)	Correlazione via analisi traffico di rete
Integrità	Merkle Tree, firma radice RSA-PSS	Forte (tamper rilevabile)	Omissione schede prima dell'inserimento
Verificabilità Individuale	Ricevuta firmata + Merkle proof	Forte (se ricevuta conservata)	Receipt-freeness non garantita
Verificabilità Universale	Pubblicazione triple + riesecuzione cifratura	Forte (dati e chiavi pubbliche)	Completezza del registro non universalmente verificabile

Tabella 1: Riepilogo della verifica delle proprietà di sicurezza

4.2 Analisi degli Avversari

In questa sezione il threat model definito in WP1 viene analizzato in relazione al protocollo di WP2. Per ciascuna categoria di avversario si valuta se le contromisure adottate siano sufficienti a neutralizzarne le capacità offensive e si identificano eventuali gap residui.

4.2.1 Gestore Disonesto (AE o SA corrotta)

Questo avversario ha accesso diretto ai database del sistema e alle chiavi private del proprio componente. I possibili obiettivi includono: alterare il conteggio, violare la segretezza, introdurre schede fraudolente o impedire la pubblicazione del risultato.

SA corrotta

- *Emissione di token extra*: il SA potrebbe rilasciare token aggiuntivi per elettori inesistenti o già votanti. La contromisura parziale è il Merkle Tree, che registra pubblicamente ogni scheda accettata; tuttavia, senza una riconciliazione pubblica tra token emessi e schede registrate, l'attacco potrebbe non essere immediatamente rilevabile. Questa lacuna è affrontata nella Sezione 4.3.1.
- *Correlazione identità-voto*: il SA conosce l'identità dell'elettore e il momento del rilascio del token. Se l'AE conserva il timestamp di ricezione della scheda, la correlazione temporale è possibile per un SA corrotto che collude con l'AE. Il rischio è mitigato dalla separazione architetturale ma non eliminato crittograficamente.

AE corrotta

- *Alterazione del conteggio*: qualsiasi modifica a schede già registrate invalida la radice del Merkle Tree firmata, rendendo l'alterazione rilevabile da chiunque.
- *Omissione di schede*: l'AE potrebbe rifiutare di registrare una scheda legittima senza che ciò sia visibile nel registro pubblico. L'unica contromisura è la ricevuta dell'elettore, che rende l'omissione rilevabile individualmente ma non universalmente in modo automatico.
- *Decifratura anticipata*: il protocollo vincola l'uso della chiave privata di decifratura tramite vincoli operativi, non crittografici. Questa limitazione è dichiarata in WP2 ed è oggetto della modifica migliorativa nella Sezione 4.3.3.
- *Pubblicazione di un risultato falso*: impossibile senza invalidare la firma sulla radice del Merkle Tree e sulle triple pubblicate, verificabili da chiunque.

4.2.2 Elettore Malevolo

L'elettore malevolo è un soggetto legittimamente registrato che tenta di ottenere vantaggi illeciti o di perturbare il sistema.

- **Double voting**: il SA garantisce che ogni elettore riceva un unico token; l'AE rifiuta token già usati. Il tentativo di inviare più schede è neutralizzato strutturalmente.
- **Invio di schede non valide (spam)**: mitigato dalla Proof of Work adattiva. In condizioni normali il costo per l'elettore onesto è trascurabile; in presenza di attacchi volumetrici la difficoltà aumenta, rendendo l'invio massivo di schede false computazionalmente oneroso. Le schede non valide vengono conteggiate come nulle senza compromettere il registro.
- **Dimostrazione del voto a terzi (coercizione)**: la ricevuta, a scrutinio concluso, consente all'elettore di dimostrare il contenuto del proprio voto. Il sistema non garantisce receipt-freeness, come dichiarato in WP2. Non sono disponibili contromisure semplici compatibili con i vincoli del progetto.
- **Replay di una scheda propria**: il token è a uso singolo e marcato come usato dall'AE all'atto della prima registrazione. Un reinvio della stessa scheda viene rifiutato per token già consumato.

4.2.3 Avversario Esterno Passivo (Eavesdropper)

Questo avversario monitora passivamente le comunicazioni tra gli attori, senza poterle modificare.

- **Intercettazione del contenuto delle schede:** il canale TLS obbligatorio cifra tutto il traffico in transito. La scheda è inoltre già cifrata con RSA-OAEP: anche in caso di compromissione del canale TLS, il ciphertext non rivela la preferenza dell'elettore.
- **Correlazione temporale identità-scheda:** un avversario che osserva il traffico può correlare il momento di invio della scheda con l'identità dell'elettore tramite indirizzo IP o orario di connessione. Il protocollo non fornisce contromisure a questo livello; tecniche di anonimizzazione della rete sono fuori scope, come dichiarato in WP2.
- **Analisi del registro pubblico:** le schede cifrate non rivelano la preferenza (RSA-OAEP probabilistico). I seed vengono pubblicati solo a scrutinio concluso, rendendo la correlazione temporale inutile durante la raccolta.

4.2.4 Avversario Esterno Attivo

Questo avversario può modificare, ritardare o eliminare messaggi in transito, lanciare attacchi replay e sovraccaricare i server.

- **Man-in-the-Middle:** il canale TLS con certificati X.509 mitiga gli attacchi MitM classici. Un attacco di key substitution (sostituzione della chiave pubblica dell'AE) è mitigato dall'autenticità dei parametri distribuiti tramite TLS, ma non è escluso crittograficamente in caso di compromissione della PKI. La mitigazione complementare tramite certificate pinning è discussa nella Sezione 4.3.4.
- **Replay di messaggi:** la validità temporale del token e il controllo di unicità da parte dell'AE neutralizzano i replay. Un token già usato viene rifiutato; un token scaduto viene rifiutato per validità temporale.
- **Modifica di una scheda in transito:** il canale TLS protegge l'integrità dei messaggi. Una modifica della scheda produrrebbe una scheda con PoW non valida o con firma del token non corrispondente, causando il rifiuto da parte dell'AE.
- **Attacchi DDoS e Brute-Force:** il protocollo mitiga gli attacchi di saturazione utilizzando difese specifiche per ciascun nodo.
 - *Lato AE (Ricezione Voti):* l'adozione di una Proof of Work (PoW) adattiva funge da filtro preventivo per lo spam prima della validazione crittografica. Il meccanismo distingue la tipologia di attacco: per gli attacchi DoS basilari, in cui la PoW non viene risolta, la richiesta viene immediatamente esclusa dall'AE senza alterare la difficoltà. Per gli attacchi più sofisticati, la difficoltà della PoW viene aumentata esponenzialmente per innalzare il costo computazionale per l'attaccante. Tale approccio richiede una calibrazione accurata dei parametri: una configurazione eccessivamente restrittiva potrebbe paradossalmente indurre una condizione di *self-inflicted denial of service*, degradando le prestazioni o impedendo l'accesso agli utenti legittimi.

- *Lato SA (Autenticazione)*: per proteggere l'endpoint di login da attacchi di forza bruta e flood di richieste, è implementato un meccanismo rigoroso di Rate Limiting su base IP. Il sistema mantiene una struttura dati in memoria (una *deque* di timestamp per ciascun indirizzo IP) che implementa una finestra scorrevole (*sliding window*): sono ammesse al massimo 10 richieste ogni 60 secondi per singolo IP. Superata tale soglia, il SA rigetta le connessioni in ingresso a basso costo computazionale, prevenendo la saturazione della CPU necessaria per la generazione e la firma RSA-PSS dei token legittimi.

4.3 Modifiche Migliorative

In questa sezione vengono identificate modifiche al protocollo di WP2 che apportano benefici netti a una o più proprietà di sicurezza senza introdurre perdite in altre. Ciascuna modifica è analizzata in termini di beneficio, impatto sulle proprietà e compatibilità con i vincoli di complessità e scalabilità dichiarati in WP1.

4.3.1 Commitment Pubblico del Numero di Token Emessi

Descrizione: Al termine della fase di autenticazione, o contestualmente alla chiusura delle urne, il SA pubblica e firma crittograficamente il numero totale di token rilasciati per l'elezione corrente. A urne chiuse, l'AE pubblica analogamente il numero totale di schede registrate nel Merkle Tree. Qualsiasi osservatore può confrontare i due valori e rilevare eventuali discrepanze.

Benefici:

- Rafforza la proprietà di unicità del voto: una discrepanza positiva (più schede che token) segnala l'inserimento di schede fraudolente da parte di un'AE corrotta.
- Introduce un meccanismo di verifica universale sul numero di partecipanti, complementare alla verifica sul contenuto delle schede.
- Non richiede modifiche al flusso di votazione né al formato delle schede.

Analisi dell'impatto sulle proprietà:

- *Unicità*: rafforzata. La riconciliazione pubblica SA-AE rende rilevabile il *ballot stuffing* senza richiedere la collaborazione dei singoli elettori.
- *Verificabilità universale*: rafforzata. La verifica si estende anche al numero di voti, non solo al loro contenuto.
- *Segretezza*: non impattata. Il commitment riguarda il conteggio aggregato, non le identità né il contenuto delle schede.
- Nessuna proprietà risulta indebolita da questa modifica.

Implementazione: Il SA firma il valore `count_token` con la propria chiave privata RSA-PSS e pubblica la coppia (`count_token`, `firma_SA`) sul registro al momento della chiusura delle urne. L'AE pubblica analogamente (`count_schede`, `firma_AE`). Entrambi i valori sono verificabili con le chiavi pubbliche già distribuite in Fase 1, senza richiedere alcuna nuova primitiva crittografica.

4.3.2 Timestamp Firmato nella Ricevuta

Descrizione: La ricevuta rilasciata dall'AE viene arricchita con un timestamp firmato che attesta l'orario esatto di accettazione della scheda. Il timestamp è incluso nel payload firmato con la chiave privata di firma dell'AE tramite RSA-PSS.

Benefici:

- Rafforza la verificabilità individuale: l'elettore dispone di una prova verificabile non solo dell'inclusione nel Merkle Tree, ma anche del momento in cui il voto è stato registrato.
- Rende rilevabile l'omissione tardiva: se l'AE ritardasse deliberatamente l'inserimento di una scheda nel registro, il timestamp nella ricevuta non corrisponderebbe all'indice progressivo della foglia, rendendo l'anomalia individuabile dall'elettore.
- Permette di rilevare registrazioni effettuate al di fuori della finestra temporale valida dell'elezione.

Analisi dell'impatto sulle proprietà:

- *Verificabilità individuale:* rafforzata. La ricevuta diventa una prova più completa e difficile da contestare.
- *Integrità:* lievemente rafforzata. L'anomalia di timing diventa rilevabile senza analisi comparativa del registro.
- *Overhead computazionale:* trascurabile. Il timestamp è incluso nel payload già firmato con RSA-PSS; non richiede operazioni crittografiche aggiuntive.
- Nessuna proprietà risulta indebolita. Il timestamp non rivela informazioni sul contenuto del voto né sull'identità dell'elettore.

Implementazione: Il campo `timestamp` viene aggiunto al payload della ricevuta prima della firma RSA-PSS dell'AE. Il formato della ricevuta diventa: { `indice_foglia`, `scheda_cifrata`, `merkle_proof`, `timestamp` }, firmato con la chiave privata di firma dell'AE. Nessuna modifica è richiesta al formato del Merkle Tree o al flusso di votazione.

4.3.3 Vincolo Crittografico sulla Chiave Privata di Decifrazione

Descrizione: Nella prima progettazione realizzata, il protocollo vincola l'uso della chiave privata di decifrazione dell'AE alla fase successiva alla chiusura delle urne tramite un vincolo puramente operativo. Si propone di formalizzare questo vincolo rendendolo parzialmente verificabile tramite un meccanismo di escrow semplificato. In una variante compatibile con i vincoli del progetto, la chiave privata di decifrazione viene cifrata con una chiave simmetrica derivata dalla radice del Merkle Tree finale firmata. L'AE può decifrarla solo dopo aver pubblicato e firmato la radice finale, rendendo le due operazioni crittograficamente sequenziali e la loro corretta esecuzione verificabile pubblicamente.

Benefici:

- Rafforza la garanzia di segretezza durante la raccolta: la decifratura anticipata richiederebbe la pubblicazione prematura di una radice non finale, che sarebbe poi incoerente con la radice vera a urne chiuse, rendendo l'anomalia rilevabile.
- Trasforma un vincolo operativo in un vincolo parzialmente verificabile, riducendo il grado di fiducia richiesto verso l'AE.

Analisi dell'impatto sulle proprietà:

- *Segretezza*: rafforzata. La protezione durante la raccolta non dipende esclusivamente dalla correttezza comportamentale dell'AE.
- La variante semplificata è compatibile con le primitive crittografiche già presenti nel sistema (RSA, SHA-256) e non richiede schemi time-lock basati su blockchain o trusted hardware.
- Nessuna proprietà risulta indebolita.

4.3.4 Certificate Pinning per la Chiave Pubblica dell'AE

Descrizione: Il client viene distribuito con l'impronta digitale (fingerprint SHA-256) della chiave pubblica dell'AE pre-installata. Anche in caso di compromissione del canale TLS o della PKI, il client rifiuta chiavi non corrispondenti al fingerprint atteso. In aggiunta, il fingerprint viene distribuito su canali indipendenti (sito istituzionale dell'università, comunicazione email istituzionale) per consentire la verifica out-of-band.

Benefici:

- Mitiga l'attacco di key substitution: un avversario che sostituisce la chiave pubblica dell'AE durante la distribuzione verrebbe rilevato dal client al momento della verifica del fingerprint.
- Riduce la dipendenza dall'intera catena di trust PKI, che potrebbe essere compromessa da una CA malevola o negligente.

Analisi dell'impatto sulle proprietà:

- *Autenticità*: rafforzata. La cifratura del voto è garantita avvenire con la chiave pubblica legittima dell'AE.
- *Segretezza*: rafforzata indirettamente. Un attacco di key substitution avrebbe consentito a un avversario di decifrare le schede; il pinning lo neutralizza.
- Il costo implementativo è minimo: il fingerprint è un valore statico incluso nella configurazione del client al momento della distribuzione.
- Nessuna proprietà risulta indebolita.

4.3.5 Riepilogo delle Modifiche Migliorative

La tabella 2 riassume l'impatto e la complessità delle modifiche migliorative proposte.

Modifica	Proprietà rafforzata	Prop. indebolita	Complessità aggiuntiva
Commitment pubblico token emessi (§4.3.1)	Unicità, Verificabilità Universale	Nessuna	Minima (firma SA a urne chiuse)
Timestamp firmato nella ricevuta (§4.3.2)	Verificabilità Individuale, Integrità	Nessuna	Trasc. (campo payload)
Vincolo sulla chiave privata (§4.3.3)	Segretezza nella raccolta	Nessuna	Moderata (escrow semplificato)
Certificate pinning chiave AE (§4.3.4)	Autenticità, Segretezza	Nessuna	Minima (fingerprint nel client)

Tabella 2: Riepilogo delle modifiche migliorative

4.4 Compromessi Dichiarati e Motivazioni

Non tutte le proprietà di sicurezza identificate in WP1 sono pienamente soddisfatte dal protocollo di WP2, né dalle modifiche proposte in questo documento. In questa sezione si esplicitano i compromessi mantenuti, motivandone la scelta in relazione al contesto applicativo e ai vincoli di complessità dichiarati in WP1.

4.4.1 Receipt-Freeness

Il sistema non garantisce *receipt-freeness*: a scrutinio concluso, l'elettore può dimostrare a terzi il contenuto del proprio voto utilizzando la ricevuta e i dati pubblicati dall'AE. Questa limitazione è una conseguenza diretta della scelta di garantire la verificabilità individuale tramite ricevuta verificabile.

Soluzioni che eliminino questo compromesso (es. voto revocabile, schemi basati su commitment e apertura controllata) richiedono protocolli interattivi complessi non compatibili con i requisiti di semplicità e scalabilità del sistema. La limitazione è accettata in quanto il contesto universitario è caratterizzato da un rischio di coercizione organizzata strutturalmente inferiore rispetto a elezioni politiche generali.

4.4.2 Anonimato a Livello di Rete

Il protocollo garantisce la pseudonimia delle schede nel registro ma non l'anonimato della connessione di rete. Un avversario in grado di osservare il traffico può correlare l'invio di una scheda all'identità dell'elettore tramite indirizzo IP o orario di connessione. L'adozione di tecniche di anonimizzazione della rete (es. mix-net a livello di trasporto) è fuori scope, ma potrebbe essere indicata come estensione futura qualora il sistema venisse adottato in contesti a più alto rischio.

4.4.3 Segretezza Condizionata alla Non-Collusione

La segretezza del voto è garantita solo se SA e AE non colludono. In caso di collusione, è teoricamente possibile correlare i log di autenticazione con le schede cifrate tramite

analisi temporale. Soluzioni crittografiche che eliminino questa assunzione (es. blind signature, threshold decryption, mix-net) sono state considerate ma ritenute sproporzionate rispetto al contesto applicativo e ai vincoli del corso. La separazione architetturale tra SA e AE riduce il rischio nella pratica, anche se non lo elimina formalmente.

4.4.4 Disponibilità del Servizio

Il sistema non può garantire disponibilità assoluta in presenza di attacchi DDoS di grande scala. Le contromisure adottate (PoW adattiva, separazione SA-AE, scalabilità orizzontale) mitigano il rischio ma non lo eliminano. La disponibilità è considerata una proprietà *best-effort* nel contesto del progetto.

4.5 Conclusioni

L'analisi condotta in questo work package ha verificato che il protocollo definito in WP2 soddisfa le proprietà di sicurezza identificate in WP1 nelle condizioni dichiarate, con i limiti e i compromessi esplicitati.

Le proprietà di autenticità, integrità e verificabilità universale risultano robustamente garantite dai meccanismi crittografici adottati (RSA-PSS, RSA-OAEP, Merkle Tree). La segretezza del voto è garantita in modo condizionato, dipendendo dall'assenza di collusione tra SA e AE e dall'assenza di analisi del traffico a livello di rete. La verificabilità individuale è garantita, con il noto compromesso sulla receipt-freeness.

Sono state identificate quattro modifiche migliorative con benefici netti e nessuna perdita in altre proprietà: il commitment pubblico del numero di token emessi (rafforza unicità e verificabilità universale); il timestamp firmato nella ricevuta (rafforza verificabilità individuale e integrità); il vincolo crittografico sulla chiave privata di decifratura (rafforza la segretezza durante la raccolta riducendo la dipendenza da vincoli operativi); il certificate pinning della chiave pubblica dell'AE (rafforza autenticità e segretezza contro attacchi di key substitution).

I compromessi dichiarati (receipt-freeness, anonimato di rete, collusione SA-AE, disponibilità) sono motivati dalla scelta progettuale di privilegiare semplicità, verificabilità e praticabilità in un contesto universitario, in accordo con i principi di *Economy of Mechanism* e *Psychological Acceptability* richiamati in WP1.

4.6 Riepilogo STRIDE

La tabella 3 sintetizza l'analisi delle minacce condotta nel WP3 secondo il framework STRIDE, mettendo in relazione ciascuna categoria di minaccia con le proprietà di sicurezza coinvolte, uno scenario di attacco rilevante e i meccanismi adottati nel protocollo per mitigarlo.

Questo riepilogo evidenzia come le principali classi di minaccia individuate dal framework STRIDE siano state considerate esplicitamente nel progetto e affrontate tramite contromisure coerenti con le primitive crittografiche e le assunzioni dichiarate nei WP precedenti.

Categoria STRIDE	Proprietà coinvolta	Scenario di attacco	Meccanismi di mitigazione nel protocollo
Spoofing	Autenticità	Creazione di token falsi o impersonificazione di SA/AE	Autenticazione istituzionale, token firmati RSA-PSS, PKI X.509, TLS
Tampering	Integrità	Alterazione di schede o record del registro	SHA-256, Merkle Tree append-only, firma RSA-PSS della radice
Repudiation	Verificabilità individuale	AE nega la ricezione di una scheda valida	Ricevuta firmata dall'AE, verifica pubblica
Information Disclosure	Segretezza	Correlazione identità-voto o lettura del contenuto	RSA-OAEP probabilistico, separazione SA/AE, assenza di identificativi
Denial of Service	Disponibilità	Saturazione di SA o AE con richieste massive	Rate limiting, Proof of Work adattiva, separazione dei componenti
Elevation of Privilege	Autenticità / Unicità	Accettazione di voti senza token valido	Verifica del token, registro dei token usati, separazione SA/AE

Tabella 3: Analisi delle minacce secondo il framework STRIDE

5. WP4 – Implementazione e Prestazioni

5.1 Architettura Software e Stack Tecnologico

- **Linguaggio di Sviluppo:** L'intero ecosistema software è stato realizzato utilizzando Python 3, garantendo versatilità e leggibilità del codice sorgente.
- **Primitive e Sicurezza:** In linea con le direttive di progetto, non sono stati implementati algoritmi proprietari; il sistema integra la libreria `cryptography` (modulo `hazmat`) per la gestione di RSA con padding OAEP per la riservatezza e RSA-PSS per l'autenticità di firme e token.
- **Integrità dei Dati:** Per il calcolo delle impronte digitali necessarie alla Hash Chain e ai meccanismi di protezione anti-spam, è stata impiegata la libreria standard `hashlib` con algoritmo SHA-256.
- **Infrastruttura di Rete:** I nodi SA ed AE operano come microservizi indipen-

denti basati su Flask, esponendo interfacce API REST per la gestione orchestrata di autenticazione e ricezione dei voti.

- **Interazione Client-Server:** La comunicazione tra i terminali di voto e le autorità è mediata dalla libreria `requests`, che facilita lo scambio di pacchetti JSON su protocollo HTTP.
- **Librerie Ausiliarie:** Sono stati utilizzati i moduli nativi `json` per la formattazione dei dati, `datetime` per il controllo rigoroso della finestra temporale e `os.urandom` per la generazione di entropia crittografica.
- **Analisi del Traffico:** Per la suite di test e la generazione di carichi sintetici verso l'infrastruttura server, è stata integrata la libreria `locust`.

5.1.1 Disaccoppiamento dei Moduli

- **Interfaccia Elettore (`client.py`):** Implementa la logica lato client, gestendo la cifratura locale, la risoluzione della PoW e la successiva verifica delle ricevute crittografiche rilasciate dall'autorità.
- **Sistema di Autenticazione (`sa.py`):** Nodo dedicato esclusivamente alla validazione delle credenziali istituzionali e all'emissione di token univoci firmati digitalmente, garantendo l'anonimato rispetto al contenuto del voto.
- **Autorità Elettorale (`ae.py`):** Gestisce l'urna elettronica, verificando l'integrità dei pacchetti ricevuti e aggiornando la Hash Chain pubblica prima di procedere allo scrutinio finale mediante la propria chiave privata.
- **Verificatore Indipendente (`observer.py`):** Modulo isolato per la validazione universale post-elettorale, incaricato di ispezionare il registro pubblico per attestare la correttezza dell'intero processo di computazione.

Questa suddivisione funzionale assicura una rigorosa separazione dei compiti, impedendo a ogni singolo attore di compromettere la riservatezza o la correttezza della consultazione.

5.2 Implementazione delle Primitive Crittografiche

L'architettura di sicurezza integra algoritmi consolidati per soddisfare i requisiti teorici, avvalendosi esclusivamente della libreria `cryptography` ed escludendo lo sviluppo di primitive proprietarie.

- **Cifratura del Voto:** La riservatezza della preferenza è assicurata mediante lo schema asimmetrico RSA con padding OAEP. In fase di invio, il modulo client genera un seed casuale tramite `os.urandom`, garantendo entropia per la protezione della scelta dell'elettore sotto la chiave pubblica dell'AE. L'integrazione di SHA-256 e il carattere probabilistico della cifratura offrono sicurezza IND-CPA, rendendo i ciphertext di voti identici sempre distinti per prevenire attacchi a dizionario.
- **Firme Digitali e Token:** Per validare l'autenticità dei pacchetti e neutralizzare tentativi di alterazione, il SA emette token firmati digitalmente in formato RSA-PSS. Tale schema, basato su *Probabilistic Signature Scheme*, offre robuste garanzie

contro la manipolazione dei dati. La medesima tecnologia è impiegata dall'AE per sigillare le ricevute elettroniche e blindare l'integrità del registro pubblico.

- **Canale di Comunicazione (TLS e Certificate Pinning):** In questa fase di prototipazione, finalizzata alla convalida delle logiche di sicurezza, si è optato per l'integrazione nativa del protocollo HTTPS attraverso l'impiego di certificati X.509 autogenerati (self-signed), prescindendo temporaneamente dall'adozione di una Certification Authority (CA) commerciale o istituzionale centralizzata. Sebbene l'infrastruttura sia testata in ambiente localhost, l'iniezione dei contesti SSL obbliga i client e i server a comunicare esclusivamente su canali cifrati point-to-point. Questa scelta progettuale non solo protegge l'intercettazione passiva del traffico, ma ha consentito di implementare e validare efficacemente difese applicative avanzate contro gli attacchi Man-in-the-Middle (MitM), delegando al client la verifica rigorosa dell'identità dei server tramite meccanismi di *Certificate Pinning*.

5.3 Struttura del Registro Pubblico (Bulletin Board)

Il nucleo della trasparenza risiede nel meccanismo di memorizzazione, gestito tramite un file JSON locale (`data/bulletin_board.json`) che funge da registro pubblico (Bulletin Board).

- **Sviluppo della Struttura Dati (Merkle Tree):** Rispetto ad una classica "Hash Chain" lineare, il progetto è stato ottimizzato adottando un Albero di Merkle (Merkle Tree) per garantire un'efficienza logaritmica nella verifica. Ogni record inserito nel Bulletin Board contiene il voto cifrato, il seed cifrato e il timestamp. L'hash SHA-256 di questo record diventa una nuova foglia nell'albero di Merkle. L'AE restituisce al client una Merkle Proof per l'inclusione matematica.
- **Append-Only Enforcement:** Il codice del server AE impone l'immutabilità del registro in modo rigido. Le API (come l'endpoint `/vote`) permettono esclusivamente di aggiungere (append) nuovi record alla lista presente sul disco. Non è implementato alcun endpoint di modifica o cancellazione dei blocchi pregressi. Inoltre, ogni blocco aggiunto (`append_to_bulletin_board`) viene crittograficamente firmato dall'AE; eventuali alterazioni manuali del file invaliderebbero l'intero albero, rendendo la firma non valida.

5.4 Flusso d'Esecuzione e Gestione dello Stato

Il sistema è suddiviso in processi logicamente separati (SA, AE, Client) per rispettare il Principio di Separazione dei Privilegi, scandendo il flusso in fasi distinte:

- **Inizializzazione:** Eseguendo gli script di boot (es. `init_election.py`), il sistema genera automaticamente in locale le coppie di chiavi asimmetriche (pubblica/privata) per SA e AE tramite `generate_rsa_keypair()`. Le chiavi pubbliche vengono scritte nel blocco di genesi ("init") del Bulletin Board rendendole consultabili a chiunque.

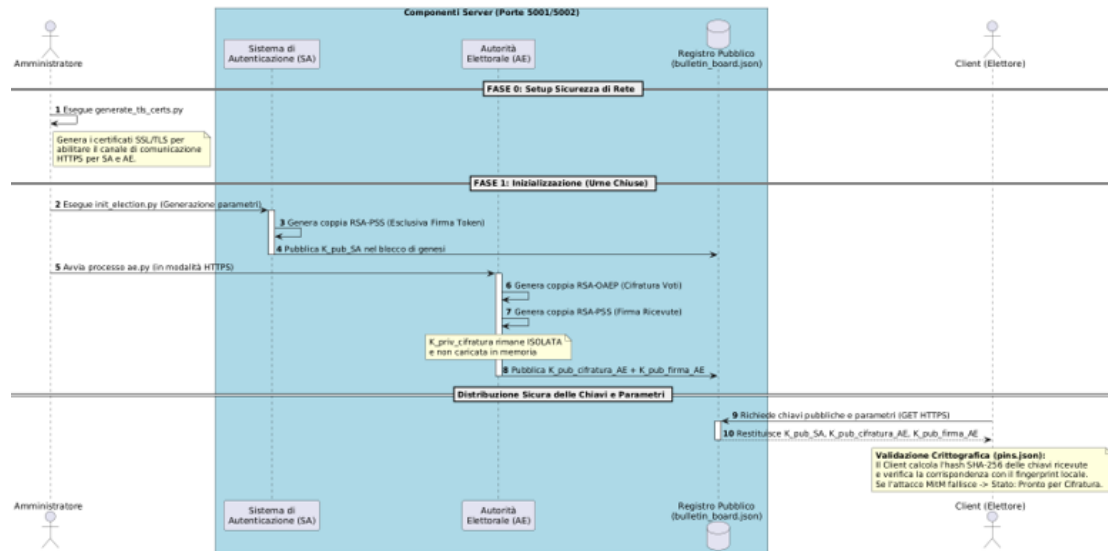


Figura 1: Diagramma di sequenza della fase di inizializzazione.

- **Autenticazione:** Il Client si autentica fornendo le credenziali al SA (Server Autenticazione). Dopo aver verificato le credenziali e il dominio, il SA genera un token univoco contenente un nonce e una data di scadenza (30 minuti), firmandolo mediante RSA-PSS prima dell'invio al Client.

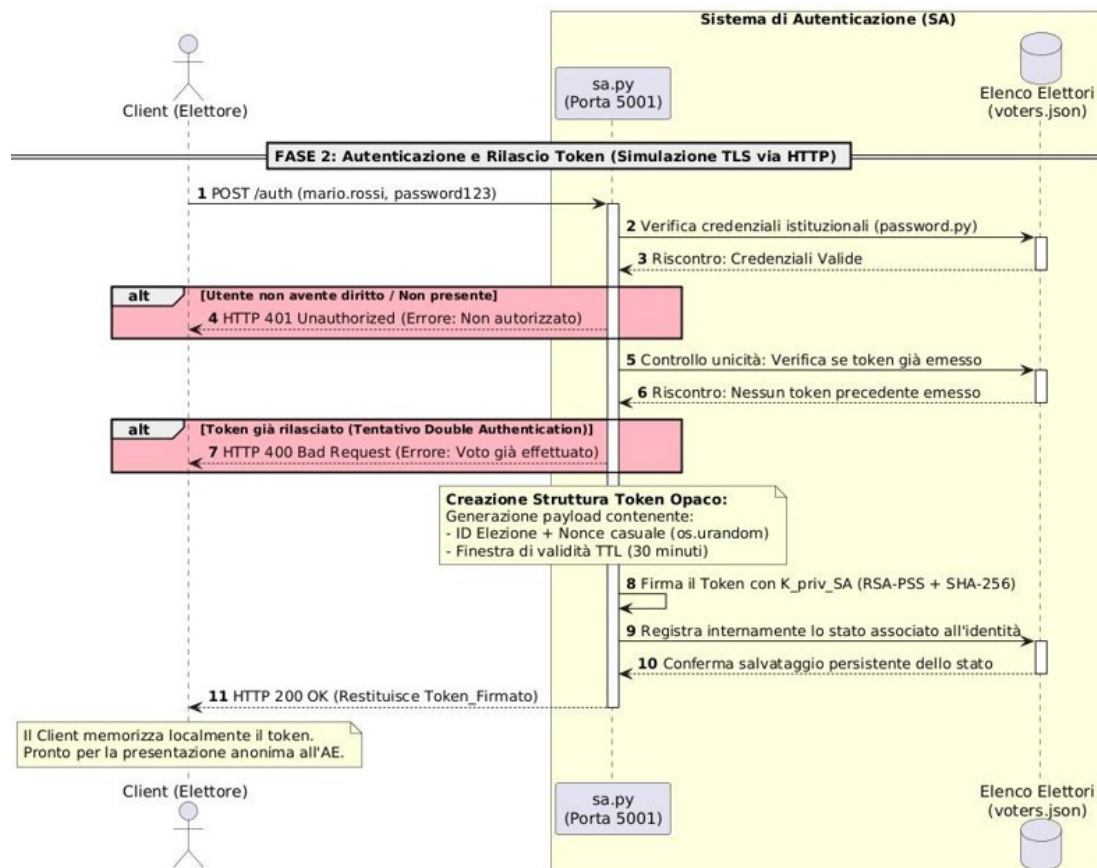


Figura 2: Diagramma di sequenza della fase di autenticazione.

- **Votazione:** L'elettore risolve la PoW e inoltra la scheda all'AE. Alla ricezione sull'endpoint `/vote`, l'AE valida la PoW, verifica la firma del SA e controlla il set dei token consumati (`used_tokens`) per prevenire attacchi di Double Voting.

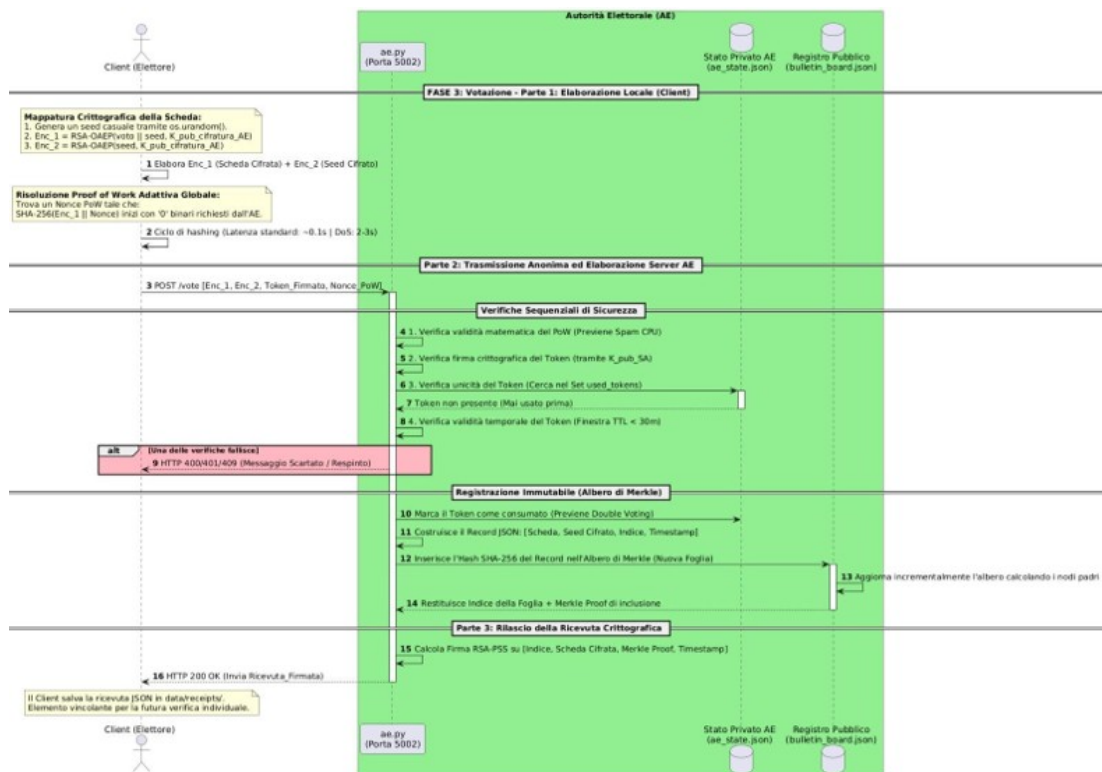


Figura 3: Diagramma di sequenza della fase di votazione.

- **Scrutinio:** Durante l'apertura delle urne, l'AE non detiene in memoria la chiave privata di decifratura (`ae_encrypt_private` è settata a `None`). La chiave privata viene istanziata unicamente invocando l'endpoint `/close` a finestre elettorali chiuse. Solo allora viene pubblicata la radice finale dell'albero di Merkle, e il server esegue la decifratura massiva iterando tutti i record validi, calcolando i totali per candidato e aggiungendo i risultati aggregati in un nuovo blocco di tipo "scrutinio".

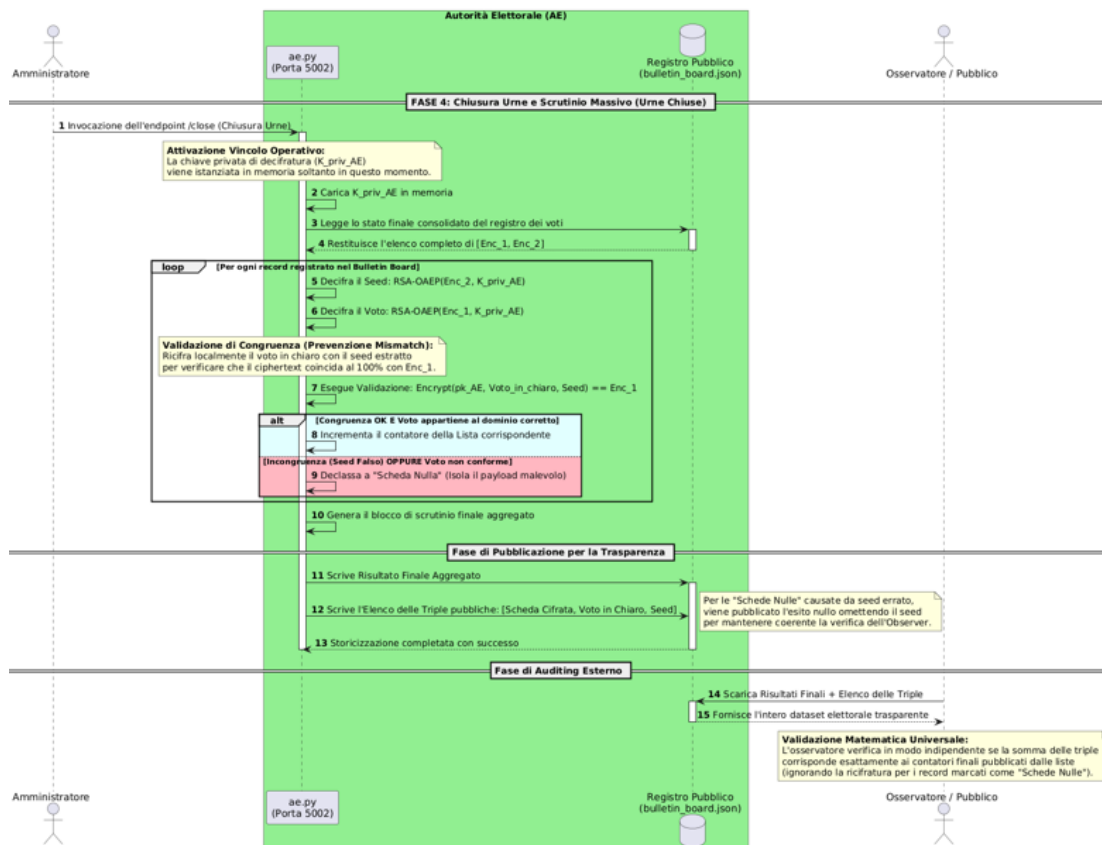


Figura 4: Diagramma di sequenza della fase di scrutinio.

- **Auditing e Validazione Post-Elettorale:** Al termine delle operazioni di scrutinio, il protocollo abilita la fase di verifica universale e individuale. L'utente, avvalendosi del modulo client, può attestare matematicamente la presenza del proprio voto validando la Merkle Proof rispetto alla radice pubblica definitiva. Contestualmente, la trasparenza è garantita dalla possibilità per soggetti terzi di ispezionare l'intero Bulletin Board, ricalcolando le impronte digitali e i totali aggregati per certificare la correttezza della computazione svolta dall'AE.

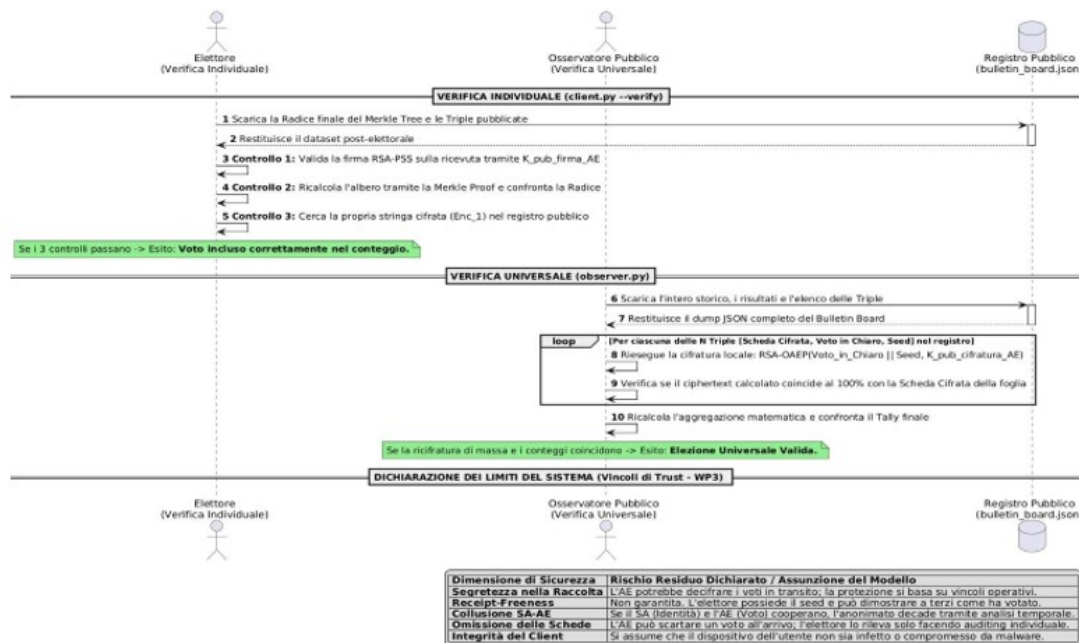


Figura 5: Diagramma di sequenza della fase di auditing e validazione post-elettorale.

5.5 Strategia di Testing e Analisi dei Casi d'Uso

La solidità è stata validata attraverso un set esaustivo di script automatici mirati sia ai casi di operatività normale che alle minacce malevole descritte nel WP3.

- **Scenario Nominale (Happy Path):** Lo script `test_flow.py` automatizza l'intera catena di eventi: dall'avvio dei server e il calcolo della Proof of Work fino all'inoltro dei voti e alla successiva validazione delle prove pubbliche tramite il modulo `observer.py`.

5.5.1 Simulazione di Attacchi (Security Testing)

- **Attacco a Dizionario e Analisi di Frequenza (`dictionary_attack_test.py`):** Verifica l'indistinguibilità del sistema (IND-CPA) e l'efficacia del padding RSA-OAEP nel neutralizzare tentativi di correlazione statistica e pre-computazione dei voti attraverso l'uso di seed ad alta entropia.
- **Iniezione di Chiavi e Man-in-the-Middle (`mitm_key_substitution_attack.py`):** Valuta la capacità del client di intercettare la sostituzione di chiavi pubbliche nel registro mediante il meccanismo di Certificate Pinning basato su parametri trusted definiti in `pins.json`.
- **Manomissione dello Storico Dati (`ledger_tampering_test.py`):** Testa l'immutabilità del Bulletin Board simulando la corruzione di record esistenti per verificar che l'effetto a valanga sull'albero di Merkle renda la frode rilevabile durante la validazione post-elettorale.
- **Vincolo Crittografico ed Escrow della Chiave Privata (`key_escrow_test.py`):** Verifica la protezione della chiave privata di decifratura dell'AE e la correttezza della transizione di escrow (WP3 - 3.3). Il test simula lo sblocco

della chiave tramite la firma dell'Init Block per il voto ed il successivo passaggio irreversibile (re-cifratura) alla firma della Merkle Root finale a urne chiuse, accertando che tentativi di decifratura prematura o non autorizzata vengano bloccati tramite controlli di integrità AEAD (AES-GCM).

- **Flood Volumetrico e Denial of Service (`dos_attack_test.py`):** Analizza la resilienza dell'AE a carichi elevati di richieste concorrenti con PoW nulla, focalizzandosi sull'efficienza del filtro applicativo nello scartare traffico malevolo senza saturare le risorse della CPU.
- **Calibrazione della PoW Adattiva (`pow_adaptive_test.py`):** Esamina i meccanismi di difesa dinamica per la gestione della difficoltà dei puzzle crittografici in base alla natura delle richieste ricevute e al monitoraggio temporale:
 1. Le richieste con PoW non risolta vengono neutralizzate senza innalzare la difficoltà globale.
 2. Attacchi sofisticati con nonce validi innescano l'incremento dell'onere per l'attaccante.
 3. Ritorno automatico alla configurazione di default allo scadere della finestra di monitoraggio.
- **Resilienza e Liveness sotto Stress (`dos_resilience_test.py`):** Convalida end-to-end il mantenimento dell'operatività per i voti legittimi tramite strategie di auto-retry lato client anche in presenza di degrado della latenza di rete.
- **Prevenzione del Double Voting e Replay (`double_voting_attack.py`):** Verifica l'unicità del voto testando la capacità dell'AE di invalidare i token nel set dei nonce consumati per respingere tentativi di sottomissione duplicata.
- **Politiche di TTL e Token Hoarding (`token_hoarding_test.py`):** Valuta la gestione delle sessioni, prevenendo l'accumulo di credenziali e verificando la scadenza temporale dei token per garantire la freshness dei dati.
- **Iniezione Seed Falso / Mismatch Crittografico (`malicious_voter_dos_test.py`):** Valuta la difesa contro utenti ostili che inviano schede con materiale crittografico errato per invalidare l'audit. L'AE rileva l'incongruenza tramite re-cifratura durante lo scrutinio, declassando tali voti a Scheda Nulla. Questa procedura neutralizza i sabotaggi alla verificabilità universale, consentendo ad `observer.py` di certificare la correttezza del processo.

5.6 Analisi delle Prestazioni e Validazione Crittografica

L'architettura del sistema è stata sottoposta a una rigorosa validazione empirica mediante una suite di test automatizzati, progettata per valutare sia la corretta implementazione delle primitive crittografiche, sia la resilienza dell'infrastruttura di rete in condizioni di sovraccarico (stress testing). L'analisi seguente rendiconta i risultati ottenuti, suddivisi in categorie funzionali.

5.6.1 Quadro Riassuntivo delle Verifiche di Sicurezza

La tabella 4 sintetizza l'esito delle simulazioni di attacco eseguite contro l'infrastruttura, correlando i moduli di test ai vettori di minaccia teorici definiti nel Work Package 3.

Modulo di Test	Output Log	Vettore di Attacco	Target / Meccanismo Difesa	Status
dictionary_attack_test.py	dictionary_attack_[...].json	Analisi di Frequenza	IND-CPA (RSA-OAEP)	PASS
mitm_key_substitution_attack.py	mitm_key_[...].json	Iniezione chiavi (MitM)	Certificate Pinning	PASS
ledger_tampering_test.py	ledger_tampering_[...].json	Alterazione registro	Immutabilità Merkle Tree	PASS
key_escrow_test.py	key_escrow_[...].json	Decifratura anticipata	Escrow chiave privata AE	PASS
dos_attack_test.py	dos_attack_[...].json	Spam Volumetrico	Scarto preventivo PoW	PASS
pow_adaptive_test.py	pow_adaptive_[...].json	DoS Distribuito	Calibrazione dinamica PoW	PASS
dos_resilience_test.py	dos_resilience_[...].json	Sovraccarico misto	Liveness (Degradamento)	PASS
double_voting_attack.py	double_voting_[...].json	Token Replay	Blocco nonce consumati	PASS
token_hoarding_test.py	token_hoarding_[...].json	Accumulo e latenza	Politica TTL e Unicità	PASS
malicious_voter_dos_test.py	malicious_voter_[...].json	Seed Falso / Mismatch	Validazione congruenza	PASS

Tabella 4: Tabella riassuntiva degli esiti dei test di sicurezza

5.6.2 Analisi Empirica e Validazione per Categoria

I log di sistema generati durante le esecuzioni forniscono parametri misurabili sull'efficienza delle contromisure applicative. Di seguito si schematizzano le evidenze tecniche per ciascun dominio di sicurezza.

A. Integrità Crittografica e Autenticazione

- **Sicurezza Semantica (Attacco Dizionario):** Il test ha confermato sperimentalmente la natura probabilistica dello schema RSA-OAEP. Sottoponendo il sistema a cifrature multiple dei medesimi candidati del dominio (es. "Lista A", "Lista B", "Lista C"), l'algoritmo ha prodotto ciphertext sempre distinti grazie all'iniezione di entropia ad ogni iterazione, rendendo inefficace l'analisi delle frequenze.

- **Prevenzione MitM (Sostituzione Chiavi):** La simulazione ha iniettato un set di chiavi pubbliche contraffatte (8c174100... e 5b5ceab6...) per intercettare il traffico di voto. La logica client ha correttamente arrestato il processo rilevando una discrepanza crittografica rispetto agli hash di pinning locali attesi (47861579... e 01c9c652...).
- **Immutabilità del Registro (Merkle Tree):** L'alterazione artificiale di un singolo byte nella foglia di indice 3, all'interno di un albero di 8 nodi, ha prodotto un effetto valanga (*avalanche effect*) sulla struttura dati. La Merkle Root è mutata da a23c0dc9... a 4d22cf72.... Le routine di validazione `original_leaf_original_proof_vs_modified_root` hanno restituito esito negativo (`false`), confermando la rilevabilità universale di qualsiasi alterazione del Bulletin Board.
- **Vincolo Crittografico della Chiave Privata (Key Escrow):** Il test ha validato l'efficacia del meccanismo di escrow semplificato della chiave privata dell'AE. I tentativi di decifratura con firme non autorizzate (K_wrong) sono stati bloccati sul nascere, sollevando l'eccezione crittografica `InvalidTag` (violazione dell'integrità del tag AES-GCM). È stata inoltre confermata sperimentalmente la transizione di stato: all'atto della chiusura delle urne, il file della chiave viene sovrascritto legando la cifratura alla firma della Merkle Root finale reale. Dopo la transizione, la vecchia firma di inizializzazione risulta definitivamente inutilizzabile per sbloccare il file, rendendo le fasi di raccolta e decifratura crittograficamente sequenziali.
- **Validazione di Congruenza e Sabotaggio dell'Audit (Mismatch Crittografico):** La simulazione ha validato la contromisura architetturale introdotta per proteggere la Verificabilità Universale da attacchi asincroni. L'avversario ha innescato con successo un voto valido nel registro pubblico, accompagnandolo tuttavia con un ciphertext alterato nel campo del seed. Poiché l'Autorità Elettorale non detiene la chiave privata durante la fase di casting, l'anomalia è stata correttamente tollerata in ingresso. Al momento dell'invocazione dell'endpoint `/close` (scrutinio), il sistema ha decifrato il payload e proceduto alla verifica di congruenza: la ricifratura in memoria del voto in chiaro con il seed estratto non ha prodotto un match con la scheda cifrata originaria. Come previsto dal protocollo aggiornato, l'AE ha immediatamente intercettato la discrepanza, negando il conteggio della preferenza e classificando il record come "Scheda Nulla". L'esecuzione successiva dell'osservatore indipendente ha confermato la validità dell'intera elezione, dimostrando che l'attacco è stato sterilizzato senza intaccare la correttezza globale del sistema.

B. Gestione Token e Prevenzione degli Abusi

- **Prevenzione del Double Voting:** Il sistema ha validato con successo la memorizzazione dello stato. Ricevuta una prima sottomissione con token valido (nonce 71992865...), l'Autorità Elettorale ha registrato il voto (HTTP 200). Un successivo tentativo di impiego del medesimo token è stato immediatamente intercettato e respinto dal protocollo (HTTP 409 Conflict).
- **Mitigazione Token Hoarding e TTL:** La reiterazione di richieste di autenticazione da parte del medesimo utente ha prodotto sistematicamente l'emissione

di copie identiche dello stesso token (stesso nonce 46b43bbe...), invalidando i tentativi di accumulo. Inoltre, l'utilizzo di un token formalmente autentico ma con marcatore temporale antecedente all'istante di validazione (`expires_at`) ha generato un rifiuto sistematico (HTTP 401 Unauthorized).

C. Valutazione delle Prestazioni Sotto Carico (Denial of Service)

- **Resilienza al Flooding Volumetrico:** Sottoposta a un carico massivo di 500 richieste distribuite su 50 thread concorrenti, recanti parametri PoW volutamente errati, l'Autorità Elettorale ha scartato le sottomissioni prima dell'attivazione delle procedure di verifica asimmetrica. Il tasso di rigetto (HTTP 400) si è attestato al 95.6% (478 su 500 richieste), con un tempo totale di elaborazione dell'intero batch di 20.71 secondi, dimostrando una spesa computazionale trascurabile per l'infrastruttura bersaglio.
- **Efficacia della PoW Adattiva:** Il sistema ha mostrato un'accurata discriminazione del traffico in ingresso. A fronte di 60 richieste invalide, la difficoltà è rimasa ancorata alla baseline (4 bit). L'iniezione di un flood computazionalmente valido (30 richieste su 6 thread) ha innescato la calibrazione dinamica della PoW. Il tempo di risoluzione locale per PoW minima è stato di circa 0.1 ms. Cessato l'attacco, il sistema ha completato il recovery ai parametri nominali in 12.0 secondi.
- **Liveness e Degradamento Controllato (Attacco Misto):** Nel test di stress più severo, il server ha affrontato la concorrenza di 20 thread di traffico invalido e 6 thread di traffico valido ostile. La difficoltà adattiva si è innalzata da 4 a 5 bit. In questo scenario di elevato rumore di rete (con un tasso di rigetto del 96.7% sui pacchetti spazzatura), 5 client legittimi su 5 hanno completato correttamente la transazione di voto. Il tempo medio di end-to-end per l'utente onesto (comprensivo del calcolo della PoW maggiorata e della latenza di rete) si è attestato a circa 4.09 secondi (es. `carlo.deluca`: 4078.0 ms), confermando che il sistema è in grado di tollerare fluttuazioni anomale del traffico garantendo un degradamento prestazionale controllato e preservando la totale operatività (liveness).

Per una maggiore chiarezza analitica, le metriche temporali e prestazionali estratte dai test di carico sono sintetizzate nella tabella 5.

5.7 Vincoli Sperimentali e Limiti del Testbed

Al fine di interpretare correttamente i parametri prestazionali emersi, segnatamente per quanto concerne la resilienza al Denial of Service e la garanzia di Liveness, risulta fondamentale contestualizzare i vincoli architetturali intrinseci all'attuale ambiente di simulazione.

La suite di validazione ha previsto l'esecuzione simultanea dei nodi autoritativi (SA ed AE) e dei carichi sintetici generati da client legittimi e botnet ostili su un'unica macchina fisica operante in localhost. Tale scenario innescava una saturazione delle risorse hardware, poiché la CPU deve orchestrare contemporaneamente la risoluzione della PoW tramite SHA-256, le operazioni asimmetriche RSA-OAEP e l'ingente overhead

Scenario di Test (Modulo)	Condizioni di Carico	Metrica Rilevata	Valore Misurato
Risoluzione PoW Baseline (<code>pow_adaptive_test.py</code>)	Assenza di traffico anomalo (Difficoltà minima: 4 bit)	Tempo medio di risoluzione locale (Client)	≈ 0.1 ms
Recovery PoW (<code>pow_adaptive_test.py</code>)	Termine di un flood valido (30 req su 6 thread)	Tempo di ripristino alla difficoltà nominale	12.0 s
Flooding Volumetrico (<code>dos_attack_test.py</code>)	500 richieste PoW errate su 50 thread concorrenti	Tempo totale di elaborazione del batch (Server AE)	20.71 s
Liveness / Attacco Misto (<code>dos_resilience_test.py</code>)	20 thread invalidi + 6 thread ostili validi simultanei	Latenza end-to-end per transazione utente onesto (inclusa PoW 5 bit)	≈ 4.09 s (4078.0 ms)

Tabella 5: Metriche prestazionali e temporali sotto stress test

derivante dal *context switching* tra i numerosi thread concorrenti sull'interfaccia di loopback.

Pertanto, i tempi di latenza end-to-end rilevati (pari a ≈ 4.09 s sotto stress) e le velocità di processamento dei batch volumetrici rappresentano una stima cautelativa e pessimistica delle prestazioni. In un ecosistema di produzione distribuito, con infrastrutture dedicate per le autorità ed endpoint indipendenti, la cessazione della contesa locale delle risorse garantirebbe una sensibile contrazione dei tempi di risposta. Il mantenimento della piena operatività e l'integrità del flusso di voto in queste condizioni di stress hardware estremo attestano, in via definitiva, l'elevata robustezza della logica applicativa implementata.